



NIST SP 800-207 Zero Trust Architecture

VMware Cloud Foundation 9.1

June 23, 2026

Table of Contents

Disclaimer.....3

Version.....4

Introduction.....4

Additional Resources4

Third Party Identifiers and Mappings4

Coverage Levels4

Controls..... 6

Disclaimer

This document is intended to provide general guidance for organizations that are considering Broadcom solutions. The information contained in this document is for educational and informational purposes only. This document is not intended to provide advice and is provided “AS IS.” Broadcom makes no claims, promises, or guarantees about the accuracy, completeness, or adequacy of the information contained herein. Organizations should engage appropriate legal, business, technical, and audit expertise within their specific organization for review of requirements and effectiveness of implementations.

Version

910-20260623-01

Introduction

This document describes how VMware Cloud Foundation (VCF) 9.1 and the separately licensed advanced services assessed alongside it, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, and VMware Avi Load Balancer, can support organizations designing zero trust architectures guided by NIST SP 800-207. NIST Special Publication 800-207, Zero Trust Architecture, defines zero trust in terms of seven basic tenets that a zero trust architecture is designed and deployed to adhere to, covering resources, communication security, per-session access, dynamic policy, asset integrity monitoring, dynamic authentication and authorization, and continuous improvement from collected telemetry. The SCF 2026.1 crosswalk maps to these seven tenets. Each assessed product is reported separately for every control, with VCF covering the full platform, including its consumption services and Private AI Services capabilities. The responsibility for designing, deploying, and operating a zero trust architecture remains with the organization.

<https://csrc.nist.gov/pubs/sp/800/207/final>

This guidance evolves. Please check the current revision at: <https://brcm.tech/vcf-compliance>

Additional Resources

This is one of a library of companion guides that map VMware Cloud Foundation and its advanced services to security and compliance frameworks. For each framework, the guide is published as a spreadsheet, a CSV data file, a Markdown document, and a PDF, together with a Security Configuration Guide crosswalk that identifies the VCF technical hardening settings relevant to that framework. The companion guide library, the VMware Cloud Foundation Security Configuration Guide, and related security documentation, sample scripts, and Q&A are available at <https://brcm.tech/vcf-security>.

Third Party Identifiers and Mappings

This document includes regulatory compliance and security control identifiers from external sources as a convenience to end users. This does not constitute endorsement, in either direction.

There is not a one-to-one mapping of product capabilities to third-party controls. A product capability, or set of capabilities, may be applicable to multiple controls. Conversely, a control may be satisfied with the use of multiple capabilities.

Control identifier numbers have been included from the Secure Controls Framework, version 2026.1, under the terms of the Creative Commons Attribution-NoDerivatives 4.0 International Public License. No modifications have been made to the control identifier numbers under the terms of the license.

<https://securecontrolsframework.com/>

Coverage Levels

Each control entry below carries the framework control text, the SCF control or controls it maps to, and an Aggregate Coverage line showing the strongest position any one of the assessed products holds for that control. Products that meet or contribute to the control follow as subsections, each with its own coverage level and response. Products the control does not apply to are listed together at the end of the entry, with a brief explanation. The coverage levels are:

- **Meets** -- the product directly provides the capability described in the control. No additional organizational process, external product, or human activity is needed beyond configuring the product itself.
- **Contributes** -- the product provides technical capabilities that help satisfy the control, but the control also requires something outside the product to be fully met, such as an organizational process, human activity, or an additional tool.

- **Not Applicable** -- the control does not apply to the product. Physical facility controls, staffing decisions, organizational governance processes, and domains the product does not operate in fall here.
- **Not Supported** -- the control is relevant to the product's domain (infrastructure, networking, security), but the product lacks the specific capability the control requires.
- **Not Assessed** -- the control has not yet been evaluated against the product.

Controls

Control Tenet 1

All data sources and computing services are considered resources. A network may be composed of multiple classes of devices. A network may also have small footprint devices that send data to aggregators/storage, software as a service (SaaS), systems sending instructions to actuators, and other functions. Also, an enterprise may decide to classify personally owned devices as resources if they can access enterprise-owned resources.

SCF Controls: AST-01, AST-01.1, AST-02, AST-02.3, AST-02.8, AST-02.9, AST-04, AST-04.1, CLD-01, CLD-13, DCH-01, DCH-02, DCH-06.2, DCH-13.4, DCH-24, MDM-01, MDM-02, MDM-06, MDM-07, PRI-05.5, TPM-01.1

Aggregate Coverage: Contributes

VCF (Contributes)

VCF contributes to IT Asset Management programs through built-in inventory, discovery, and integration capabilities that provide the technical foundation for asset tracking and governance.

VCF Operations groups discovered objects logically and provides detailed inventory lists across the environment, covering compute, storage, and networking resources. The inventory management interface supports sorting, searching, and object tagging to organize assets at scale. Custom object groups are containers that collect data from included objects and report on the data collected, allowing administrators to create dashboards and widgets that display resource information for grouped assets. VCF Operations also applies policies to newly discovered objects, such as objects added to an object group.

The Service Discovery adapter automatically discovers applications, services, and their associated metrics (CPU, memory) running on managed infrastructure. Discovery rules can be defined using object types including metrics, relationships, properties, object names, and tag-based criteria. Discovered applications can be exported in CSV format for use in external asset tracking systems.

For organizations using ServiceNow, VCF provides two integration paths. The Management Pack for ServiceNow in VCF Operations populates the ServiceNow CMDB with discovered resources through the ServiceNow Table API and CMDB Meta API, providing CMDB visibility within VCF Operations. VCF Automation also integrates with ServiceNow for ITSM and CMDB synchronization, configurable through extensibility action scripts or through VCF Operations Orchestrator Client hosted workflows. The ServiceNow ITSM Plug-in for VCF Automation provides a structured data source that captures extensive asset metadata, including resource name, operational status, project assignment, storage details, account and region information, endpoint type, zone, environment, and custom properties. The plug-in stores machine resource records in custom ServiceNow CMDB tables that track creation timestamps, deployment IDs, machine IDs, entitled users, and network schema. Deployment records similarly capture blueprint version, project ID, catalog ID, organization ID, operational status, owner, requester, and expiration tracking. The plug-in supports day-2 resource lifecycle actions such as Add Disk, Resize, Power On/Off, Create Snapshot, and Delete, and maintains CMDB accuracy through reconciliation.

VCF Automation adds governance through its project model, which controls who can deploy what resources and where those resources are deployed. Projects link users, catalog items, and IaaS resources together. Organizations in VCF Automation support policy-based governance on resource usage, allowing IT teams to monitor resource consumption, control permissions, and provide managed services with network isolation. Each organization maintains a secure boundary from other organizations. Resource quota policies can be defined through the Policies API to limit resources consumed by each user, project, or organization. Day 2 Action policies restrict which users have access to specific lifecycle operations on deployed resources.

Tags within VCF Automation express capabilities and constraints that define deployments. Cloud administrators can place constraint tags on projects to exercise governance over resource provisioning, supporting asset classification and controlled placement of workloads across the infrastructure.

The broader ITAM program responsibilities of establishing asset governance policies, defining ownership lifecycles, and maintaining organizational accountability remain outside VCF's scope.

VMware vDefend (Contributes)

VMware vDefend (DFW) and Gateway Firewall (GFW) can enforce network-level access controls that restrict which systems are able to communicate with internal resources. By applying policy rules based on workload identity and group membership, administrators can limit data flows to approved assets and block unauthorized endpoints from reaching internal services. The GFW supports enforcement of isolation between projects, allowing enterprise administrators to deny all inter-project communication except for essential infrastructure protocols such as DHCP, DNS, NTP, and ICMP, providing a boundary that limits which systems can reach internal resources.

Security Services Platform's Platform Inventory provides the visibility needed to support these restrictions. Administrators can filter monitored assets by Name and Status to identify infrastructure assets and their operational state. The inventory identifies assets that are timed out or out of sync, providing early indication when a system's status may no longer match its approved configuration. Platform Inventory organizes assets into Regions and Zones with a hierarchical structure and displays assigned tags for each infrastructure asset, supporting verification of tag assignments.

Security Intelligence's asset collections include groups, infrastructure assets, environments, applications, and application tiers. The Asset Collections view includes nodes representing entities that communicated with members of defined groups but are not part of the NSX inventory, giving administrators visibility into systems interacting with internal resources that fall outside the known asset baseline. This capability helps identify potential non-organizationally owned systems that are communicating with internal workloads. Security Intelligence Workload Classification allows administrators to mark compute entities as 'Others (Non-infrastructure)' to indicate that an entity does not provide infrastructure services, supporting identification of non-standard workloads. Security Services Platform also identifies and publishes application assets, classifying them as critical or regular, to support targeted policy application.

These capabilities provide the network enforcement and asset visibility mechanisms that help administrators identify and restrict access by non-organizationally owned systems. vDefend does not manage procurement, asset authorization, or cataloging decisions; those remain organizational governance processes outside the product's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) contributes to network architecture and data flow documentation through its network mapping capabilities, which record the topology between protected and recovery sites and provide programmatic access to that information for inclusion in formal diagrams.

PNR supports site-wide network mappings that define how networks on the protected site correspond to networks on the recovery site. These mappings can specify a different network to use during recovery plan tests, capturing the separate set of data flows that apply during DR exercises. For stretched storage environments, network mappings can be configured manually to override automatic mapping behavior between sites.

The Protection and Recovery Plug-In for the VCF Operations orchestrator provides API workflows that enumerate these mappings programmatically. The Get Network Mappings workflow lists all networks on a local site with existing mappings. The Get Network Mapping Pairs workflow retrieves the full set of mapping pairs for a specified site. The Get Test Network Mapping Pairs workflow lists test network mappings between corresponding objects across the remote site, and can query both protected and recovery sites when both are registered as local, providing a complete picture of the site-to-site network topology. An Add Test Network Mapping to Recovery Plan workflow maps a remote network to a test network within a specific recovery plan. IP customization workflows allow per-mapping customization of IP mapping rules and can remove customization rules from existing mappings.

The Plug-In also supports inventory mapping workflows that span folder mappings, network mappings, resource pool mappings, and test network mappings, providing a unified interface for enumerating all inter-site relationships.

Organizations should incorporate PNR's network mapping data and Plug-In workflow outputs into their formal network architecture diagrams to document DR topology, test network configurations, and the data flows that traverse the replication paths between sites.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to asset inventory requirements by providing built-in visibility into the database instances, infrastructure resources, and users it manages. This visibility supports tracking and accountability for the subset of technology assets that DSM governs. Organization-wide TAASD inventory across all asset categories requires organizational processes and additional tooling beyond DSM itself.

DSM tracks the association between deployed databases and the infrastructure policies under which they were provisioned. Administrators can review databases and their configuration details through the Databases tab in the Infrastructure Policies view of the DSM Administrator UI, which displays each policy alongside the databases bound to it. Because infrastructure policies define the compute, storage, and networking resources allocated to databases, including allowed VM classes, this view gives administrators a structured picture of how platform resources are being consumed. The About the DSM UI Views section confirms the Infrastructure Policies view lists all policies available in the environment and the databases associated with each.

DSM administrators can define and configure data service policies for the data services DSM manages, supporting compliance with organizational standards across tenants. Each policy can be tailored to specific requirements and assigned to one or more organizations to enforce consistent configurations. For tenant-facing self-service, the DSM Consumption Operator creates infrastructure policies as cluster-scoped resources in the consumption cluster and requires an allowedInfrastructurePolicies list that defines which policies a tenant cluster may use, giving administrators a clear inventory of the policies in scope per cluster. Tenant users create and consume databases under a Supervisor namespace through the VCF Automation Cloud Consumption Interface (CCI), and the DSM portal exposes a Consumption Operator endpoint that provides access to deployment artifacts.

For database-level visibility, the Database Health view in the DSM UI collects metric data for each database instance and cross-references alerts with resolution paths. DSM deploys a Telegraf agent on the Provider Appliance and a local Telegraf agent on each workload cluster to gather VM-level metrics such as CPU, memory, and disk usage, plus engine-specific metrics. DSM can forward metrics to an external Metrics target server, supporting integration with external monitoring or inventory aggregation systems.

For auditors, DSM's inventory-relevant information is accessible through the Administrator UI and is available to personnel with the Admin role. The Databases tab, Infrastructure Policies view, Database Health view, and Consumption Operator policy inventory collectively provide the granularity needed to account for DSM-managed database assets and the policies governing them. The documented DSM user roles (vSphere administrator, VCF Automation organization administrator, VCF Automation project user) clarify which personnel have visibility into which inventory views.

DSM provides resource tracking and visibility within its own management scope. DSM does not perform organization-wide asset discovery and does not inventory physical infrastructure, non-database applications, or data assets outside its management domain. A TAASD inventory program spanning all asset categories requires a CMDB or dedicated asset management solution that can aggregate DSM resource data alongside information from other platform components.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several application-layer mechanisms that support the implementation of data protection controls within a VCF deployment.

At the transport layer, Avi performs TLS termination with configurable SSL/TLS profiles for connections between clients and virtual services. The SSL/TLS protocol at the Avi proxy secures data in transit by reducing the risk of unauthorized parties reading or modifying information transferred between end users and application workloads. SSL/TLS profiles are configurable through the Avi Controller UI under Templates > Security > SSL/TLS Profile. Management interface access is further restricted through configuration of allowed ciphers and HMACs for management sessions.

Avi integrates with Hardware Security Modules (HSMs), including the Thales Luna (formerly SafeNet Luna) HSM, for cryptographic key storage and management. This allows organizations to store the private keys used in TLS termination and other cryptographic operations within a dedicated hardware key store rather than in software. The Avi Controller also stores sensitive configuration data encrypted in a local database, and backup files can be protected with a passphrase that encrypts the keys included in the backup. Backup and restore operations verify that the FIPS mode of the backup configuration matches the target controller environment.

Avi's Web Application Firewall (WAF) applies both positive and negative security models to inspect and filter HTTP/HTTPS application traffic. WAF policies support ModSecurity rules for application protection and a Positive Security model that learns application behavior to define allowed request patterns. The Application Rules service, available through the Avi Cloud Console, provides WAF rules specifically designed to address known application vulnerabilities including CVE-tracked issues, with automatic updates to keep rules current. WAF configuration is accessible through the Controller UI under Templates > Security > WAF Policy.

Avi DataScript provides a programmable layer for enforcing additional data protection behaviors at the proxy boundary. DataScripts are Lua-based scripted rules that allow inspection and manipulation of client HTTP requests and server HTTP responses, supporting content switching, redirection, header manipulation, and logging. DataScript can be used to enforce cipher suite policies by denying clients connecting with unsupported ciphers. DataScript also supports blocklist-based access control by checking client IP addresses against named IP groups and terminating connections from blocked sources while logging the violation. XML-based DataScript use cases can extract client identifiers from request payloads and compare them against configured string groups to restrict access to authorized clients.

Access to Avi configuration objects is restricted through granular role-based access control (RBAC). Avi supports extended granular RBAC using label-based markers to restrict user permissions to specific resources based on key-value pair matching. The RBAC model differentiates Read and Write access across objects such as SSL/TLS Profiles, PKI Profiles, Authentication Profiles, IP Address Groups, and Health Monitors, allowing organizations to scope access to data protection-relevant configuration to authorized roles only. Roles can also be scoped to tenants through label group associations.

These mechanisms address data protection at the application delivery layer. Broader organizational data protection controls, including data classification policies, data handling procedures, and data-at-rest protection beyond the Avi proxy boundary, require organizational governance and platform-level capabilities that Avi does not provide as an application delivery controller.

Control Tenet 2

All communication is secured regardless of network location. Network location alone does not imply trust. Access requests from assets located on enterprise-owned network infrastructure (e.g., inside a legacy network perimeter) must meet the same security requirements as access requests and communication from any other nonenterprise-owned network. In other words, trust should not be automatically granted based on the device being on enterprise network infrastructure. All communication should be done in the most secure manner available, protect confidentiality and integrity, and provide source authentication.

SCF Controls: CRY-01, CRY-03, CRY-04, CRY-07, CRY-08, IAC-01.2, IAC-04, NET-01, NET-14.2, NET-14.5, NET-15

Aggregate Coverage: Meets

VCF (Meets)

VCF provides cryptographic protection for data in transit across management, compute, storage, and inter-site networks. The architecture applies encryption at multiple layers using validated cryptographic modules and current TLS protocol versions.

VCF management and monitoring communications use TLS as the transport protocol. VCF Operations for Networks supports modern TLS protocol versions, with the ability to restrict cryptographic module usage to FIPS-validated modules by enabling FIPS mode for external connections. Telegraf, the metrics collection agent, is configured to require a modern minimum TLS version for its communication channels. When using the databus for on-premises environments, HTTPS is the recommended transport to protect data during transmission and to verify subscriber authenticity. The TLS implementation includes customizable PKI options ranging from fully automated certificate management within VCF to integration with enterprise PKI infrastructure such as Microsoft Active Directory Certificate Services. VCF Operations provides centralized certificate lifecycle management across VCF components, supporting auto-renewal for VMCA, MSCA, and OpenSSL CA, handling automated renewal, monitoring, and replacement. Machine SSL certificates can be renewed through the API for a specified period up to 730 days. Starting in vSphere 9.0, all vSphere TLS profiles are FIPS compliant, and the COMPATIBLE profile supports modern TLS cipher suites and elliptic curves. The vCenter appliance uses VMware's Boring Crypto Module version 6.0, which provides FIPS-validated cryptographic operations including AES, ECDSA, HMAC, RSA, and SHA-2 variants.

NSX, which provides networking services within VCF, uses FIPS 140-3 validated cryptographic modules by default. These modules are validated through the NIST Cryptographic Module Validation Program. NSX Manager uses FIPS 140 approved algorithms for authentication to its cryptographic module. For site-to-site connectivity, the NSX L2 VPN FIPS compliance suite uses FIPS-approved encryption with Perfect Forward Secrecy enabled and standardized Diffie-Hellman key exchange, providing transmission confidentiality for tunneled traffic. VCF Operations for Networks supports modern ECDSA and RSA signature algorithms for data source connections.

VCF Automation uses the BouncyCastle FIPS 2.0.0 cryptographic module, which is compliant with FIPS 140-3 (Certificate #4743). VCF Operations for Networks uses the BC-FJA (Bouncy Castle FIPS Java API) version 2.0.0 with FIPS 140-2 Certificate #37009. These validated modules underpin the cryptographic operations used for securing communications across the automation and operations components.

At the storage layer, vSAN provides data-in-transit (DIT) encryption that protects data as it moves between hosts within the cluster. DIT encryption is a cluster-wide setting that, when enabled, encrypts all data and metadata traffic across hosts. Forward secrecy is enforced for vSAN data-in-transit encryption, meaning that compromise of a long-term key does not expose previously encrypted traffic. DIT encryption operates independently of data-at-rest encryption and does not require external key management servers. The behavior differs by storage architecture: in vSAN Original Storage Architecture (OSA), data-at-rest encryption occurs at the target host's Local Object Manager layer, so data traverses the network before encryption, making DIT encryption strongly recommended. In vSAN Express Storage Architecture (ESA) in HCI mode, data is encrypted at the VM host before network transmission, making DIT encryption optional based on compliance requirements.

VM Encryption provides confidentiality protection across all datastore types including vSAN, iSCSI, NFS, and Fibre Channel. VM encryption is implemented on the ESX host rather than on the storage array, so it protects data both at rest and in transit to the storage backend. Disk encryption uses AES-256 as the disk encryption key.

Encrypted vSphere vMotion protects VM data during live migrations. For encrypted VMs, vMotion always uses encryption and cannot be disabled. For unencrypted VMs, encrypted vMotion offers three settings: Disabled, Opportunistic (default, uses encryption when supported), and Required. AES-NI significantly improves encryption performance for these operations. Cross-vCenter vMotion supports encryption when source and destination use shared key providers; vCenter Crypto Manager provides an importProvider method to import a vSphere Native Key Provider configuration between sites. vSphere Fault Tolerance log traffic, which synchronizes VM state between primary and secondary instances, can also be encrypted to protect this synchronization data in transit.

Storage protocol support varies by type. vSAN File Service supports NFS4 Kerberos authentication with security options krb5, krb5i, and krb5p, where krb5p provides authentication plus encryption of data in transit. iSCSI uses CHAP for session authentication but does not encrypt data natively, so VM Encryption or in-guest encryption is needed for confidentiality on iSCSI networks. Fibre Channel Gen 7 supports end-to-end encryption with secure Host Bus Adapters.

HCX Network Extension services support transport encryption for data between site pairs, and this encryption is enabled by default. VCF Operations HCX tunnel encryption similarly uses transport encryption by default to protect Network Extension data and migration traffic between sites. This default-on approach reduces the risk of data being transmitted in cleartext during workload migrations or network extensions.

High-quality entropy generation on ESX hosts supports the proper functioning of security-related operations such as generating encryption keys for secure network communication. This foundational capability helps maintain the strength of cryptographic keys used across all transmission encryption functions in the platform.

VMware Kubernetes Service (VKS), which runs on vSphere Supervisor, applies TLS encryption across all control-plane communication paths. The Kubernetes API server enforces encrypted transmission within the control plane and between the control plane and its clients by default, so all API server interactions travel over TLS. Cipher suites are configurable at each component layer: the kube-apiserver `--tls-cipher-suites` parameter accepts a comma-separated list of permitted cipher suites; the kube-scheduler exposes the same `tls-cipher-suites` parameter to keep its API endpoint aligned; and the kubelet exposes `tlsCipherSuites` and `tlsMinVersion` settings in `KubeletConfiguration` to scope the permitted cipher algorithms and minimum protocol version at the node level. Antrea, the CNI plugin included with Supervisor, supports configurable TLS cipher suites for its own secure communication channels through the `tlsCipherSuites` setting, and the vSphere Cloud Provider Interface (CPI) exposes the same capability through a configurable cipher suite list.

For environments with strict cryptographic requirements, VKS supports FIPS mode through the ClusterClass variable `fips.enabled`, which controls which encryption algorithms are permitted at the node level. TanzuKubernetesRelease references carrying the `-fips.1` suffix indicate that FIPS cryptographic modules are active for that node pool. The Istio service mesh package, available as a standard package on VKS clusters, ships with FIPS compliance and supports mutual TLS (mTLS) between pods within the mesh; the `meshMTLS.minProtocolVersion` setting controls the minimum acceptable protocol version for all inter-service traffic. Ingress-layer encryption for workloads is handled by the Contour package, which exposes `tls.minimum-protocol-version` and `tls.maximum-protocol-version` settings so operators can define a bounded range of acceptable protocol versions for inbound HTTPS traffic. The Supervisor secret injection agent automatically configures mutual TLS for its communication with the vault agent injector service using auto-generated certificates. Harbor, available as a Supervisor Service, accepts custom TLS certificates through its `tlsCertificate.tls.crt` and `tlsCertificate.tls.key` configuration fields, supporting encrypted access to the container registry for image distribution.

Defining the encryption policy for customer workload traffic, selecting cipher and FIPS configurations for environments with stricter requirements, and validating that data transmitted from customer applications and containerized workloads meets confidentiality standards are organizational data-policy decisions.

VMware Private AI Services (PAIS) provisions VKS clusters using a FIPS-enabled Kubernetes build for cryptographic compliance across both control plane and worker node communications. The VKS cluster topology version is v1.33.1--

vmware.1-fips-vkr.2 with FIPS compliance enabled, running on an Ubuntu 24.04 OS image, covering the cryptographic modules that protect data in transit within the cluster fabric.

PAIS, activated through the PAISConfiguration custom resource on the Supervisor, requires HTTPS for all external integrations. The spec.clientTls.caBundleRefs section of the PAISConfiguration YAML references CA trust bundles supplied as ConfigMap resources. Operators must configure HTTPS trust bundles for the OIDC provider, the Harbor container registry, content management systems hosting Knowledge Base data sources, MCP servers providing tools to models, and the pgvector database. Separate trust bundles are recommended per application, with periodic updates required before certificate expiration.

The PAIS Supervisor endpoint uses HTTPS on port 6443 with certificate-based authentication. The PAIS ingress endpoint is protected by a self-signed certificate stored in the pais-ingress-default Kubernetes Secret. Administrators retrieve the CA certificate using `kubectl get secrets/pais-ingress-default -o yaml` and distribute it to clients that connect to the service, including Grafana when configured to scrape the PAIS Prometheus endpoint. CA trust bundles for external entity connections are managed through ConfigMaps and updated as certificate content changes.

VCF Automation Provider Management for PAIS uses a base64-encoded certificate (TM_CERT_BASE64) obtained by running `openssl s_client` against the VCF Automation FQDN on port 443, enabling authenticated HTTPS communication between AI catalog tooling and the PAIS environment. MCP server integrations require the MCP server's issuer certificate to be added as a CA trust bundle before connecting over HTTPS using either Streamable HTTP or Server-Sent Events transport.

Telemetry sent from PAIS to the OpenTelemetry Collector is authenticated using a Kubernetes Secret containing Authorization Bearer tokens and custom authorization headers. LLM trace transport to the collector uses HTTP/protobuf or gRPC, both protecting trace traffic in transit.

One configuration detail that auditors should verify: PAIS Prometheus TLS client authentication and certificate validation are turned off by default (the `tls-client-authentication` setting on the Prometheus endpoint). Organizations should review this setting and enable mutual TLS where their policy requires it. The underlying network transport encryption between VMs and workload domains is provided by VCF and is documented in VCF Coverage.

VMware vDefend (Contributes)

VMware vDefend contributes to transmission confidentiality through inspection, visibility, and enforcement mechanisms at the network layer, while the underlying cryptographic protection of data in transit is the responsibility of endpoint applications and infrastructure components.

TLS Inspection uses a transparent TLS proxy to intercept and analyze encrypted traffic flows traversing the environment. This allows security policy to be applied to traffic that would otherwise be opaque and supports detection of threats embedded within encrypted sessions. TLS Inspection can be deployed to provide visibility into encrypted connections while preserving end-to-end encryption for flows not subject to a decryption policy, and supports both inbound and outbound inspection profiles.

Security Intelligence, integrated within the Security Services Platform (SSP), surfaces workloads communicating over application protocols that transport data without encryption. The Security Segmentation Report identifies communication chains containing at-risk unprotected members and quantifies the number of unprotected data flows hitting default-allow rules across observed traffic. Administrators can use this reporting to identify and prioritize remediation of encryption coverage gaps, including restricting or blocking cleartext protocols.

The Security Services Platform and its component services use FIPS 140-2 and FIPS 140-3 validated cryptographic modules for their own communications. Network Detection and Response (NDR) Sensors connect to the SSP using mutual TLS authentication (mTLS), with a dedicated certificate for each sensor signed by an intermediate certificate authority on the SSP. The SSP can be configured to forward log messages to a syslog server over TLS, and Malware Prevention Service remote logging likewise uses TLS to transmit log data to a remote log server. NDR also supports SSL verification for event logs sent over HTTPS. When NDR shares data to the cloud, it anonymizes sensitive customer information before transmission.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) applies cryptographic protection to the channels through which it manages paired sites and moves data between them. PNR uses TLS certificates and private keys to protect network communication and to authenticate with peer servers. The Protection and Recovery Appliance terminates TLS through an envoy proxy, and the minimum TLS protocol version is configurable by editing the `tls_minimum_protocol_version` parameter in the `envoy-proxy-config.json` file. Replication of virtual machine data between sites supports optional network-level encryption, and PNR can protect and recover virtual machines that are themselves encrypted, applying that protection through both array-based protection groups and vSphere Replication protection groups.

Authentication to vCenter and to remote PNR sites is brokered through VCF SSO. PNR acquires a holder-of-key SAML token from VCF SSO and presents it in cryptographically signed requests to remote services. The Configure Remote Site workflow imports certificates of the remote vCenter to establish trust for the cross-site connection, and the appliance prompts for VCF SSO credentials when an operator initiates operations that affect both sites.

PNR does not provide the network-layer VPN that connects paired sites. The product documentation requires that the connection between the local and remote sites of a Protection and Recovery pair be private, such as a VPN provisioned outside PNR. For isolated recovery environments used during cyber recovery operations, VMware recommends that workload user access be performed through VPN or a Remote Desktop Client rather than direct public internet exposure of recovered services.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) applies TLS-based encryption across multiple communication paths, covering database client connections, management interfaces, service-to-service communication, and data migration traffic. Starting with DSM, the platform enforces FIPS 140-3 compliant cryptographic standards and validates certificates during upload, rejecting unsupported algorithms such as Ed25519.

For database client connections, DSM enforces a minimum TLS protocol version across all supported database engines. PostgreSQL instances enforce a configurable minimum TLS protocol version via the ``ssl_min_protocol_version`` setting and support certificate-based authentication with CA verification. PostgreSQL replication connections support SSL/TLS encryption with a configurable ``sslmode`` parameter to secure data in transit between source and target databases, and DSM validates SSL trust before establishing replication. MySQL locks TLS protocol enforcement at the platform level so users cannot weaken it. MySQL has ``require_secure_transport`` set to ON by default, which requires all client connections to use encrypted transport. MySQL supports FIPS mode via the ``ssl_fips_mode`` setting. DSM adds SQL Server as a supported database engine; SQL Server clusters use TLS to encrypt client connections, require a minimum TLS version for DSM operator management, and expose the ``network.tlsProtocols`` engine setting to configure the set of allowed TLS versions.

For management and service-to-service communication, the DSM Provider exposes an HTTPS endpoint. The Consumption Operator requires a TLS certificate for secure communication with the DSM provider. In network-isolated deployments, Consumption Operator image transfers to a private registry support optional TLS certificate authentication. Metrics forwarding from DSM to VCF Operations supports mutual TLS (mTLS) authentication, requiring a client certificate and private key. DSM SMTP settings include an Auto TLS option that establishes a secure connection to the SMTP server.

DSM provides certificate management capabilities to support the TLS infrastructure. Custom certificates are validated for FIPS 140-3 compliance at upload time; accepted key types are ECDSA P-256, ECDSA P-384, and RSA with a minimum key size of 2048 bits, and Ed25519 keys are rejected as non-compliant. Trusted root certificates added through the DSM UI must comply with FIPS requirements.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides application-layer network security policy mechanisms that help organizations implement network access controls at the application delivery boundary. These Avi-native capabilities operate at the Virtual Service level and give administrators structured objects for defining, governing, and updating access rules as requirements change.

Avi's Network Security Policy evaluates incoming client traffic based on network-level parameters and determines whether a connection should be accepted, discarded, or rate-limited. IP Group-based access control lists applied per Virtual Service are the most scalable method for implementing network-layer ACLs, allowing administrators to specify which source addresses may reach individual application services. Policies can be created and modified through the Avi Controller CLI using the `configure networksecuritypolicy` command, and updated programmatically through the REST API using the Modify Network Security ACL endpoint and IP Group UUID references.

Starting with Avi Load Balancer version 32.1, NSX security groups can be used directly in both HTTP Policies and Network policies. Security groups defined once in NSX are reused across Avi Virtual Service security policies, removing the need to manually maintain IP address lists in Avi. When an IP address changes in NSX, the update propagates automatically to Avi Load Balancer, keeping Virtual Service security policies current without manual intervention. This integration provides a unified governance model where network security group membership is managed centrally in NSX and reflected automatically in Avi policy enforcement.

Avi's DDoS Policy detects and mitigates Layer 4 through Layer 7 network attacks through the Network Security policy framework, providing additional network security control at the application delivery layer.

Within the broader VCF platform, NSX provides underlay routing and network infrastructure for Avi Service Engines. East-west firewall enforcement between application tiers is provided by VMware vDefend, a separate product that extends the platform's network security posture beyond what Avi provides at the application proxy boundary.

Satisfying this control fully requires the organization to document procedures for governing and updating network security controls across the Avi tier and the broader platform, assign ownership of Avi policy objects, and establish change management processes covering both Avi Network Security Policies and VCF-layer controls.

Control Tenet 3

Access to individual enterprise resources is granted on a per-session basis. Trust in the requester is evaluated before the access is granted. Access should also be granted with the least privileges needed to complete the task. This could mean only "sometime recently" for this particular transaction and may not occur directly before initiating a session or performing a transaction with a resource. However, authentication and authorization to one resource will not automatically grant access to a different resource.

SCF Controls: DCH-01.4, DCH-13.3, DCH-14.2, IAC-01.2, IAC-02, IAC-03, IAC-04, IAC-05, IAC-08, IAC-15.1, IAC-20.1, IAC-21, IAC-21.2, NET-01.1

Aggregate Coverage: Meets

VCF (Meets)

VCF enforces role-based access control across all major platform components, restricting access to technology assets, applications, services, and data based on assigned roles with defined permissions. RBAC is applied consistently throughout the stack, covering compute management, networking, storage, operations management, automation services, and Kubernetes workloads.

VMware vCenter provides fine-grained authorization through a permissions model that associates roles with users or groups on objects in the vCenter inventory hierarchy. Roles are sets of privileges, and vCenter defines three authorization levels: operator (read-only access to configuration, the most restricted level), administrator (read and write access to configuration but cannot manage user accounts, intended for users who alter vCenter configuration or exercise control functions), and super administrator (full control). When a predefined role is modified, the updated privilege set applies immediately to all users assigned that role. New roles are created with three default system-defined privileges (System.Anonymous, System.Read, System.View), and administrators add specific privileges to match the intended access level. vCenter also supports creation of custom roles with granular privilege assignment and permission propagation to vSphere objects in the inventory hierarchy.

NSX implements RBAC by assigning users predefined roles with specific permissions. The platform includes 15 built-in roles: Enterprise Admin, Admin, Network Admin, Network Operator, Security Admin, Security Operator, Cloud Admin, Cloud Operator, Cloud Project Admin, Load Balancer Admin, Load Balancer Operator, VPN Admin, GI Platform Admin, NSX Platform Admin, and Support Bundle Collector. These roles follow the principle of least privilege, with each role carrying only the permissions needed for its functional area. NSX RBAC applies across multiple operational domains including inventory, plan and troubleshoot, and system management functions. NSX also supports project-scoped RBAC, where Network Admin, Network Operator, Security Admin, and Security Operator roles assigned within a project have permissions limited to that project's scope rather than the entire NSX system. This project-scoped model extends to VPCs and subnets within the NSX networking hierarchy. For organizations that need role definitions beyond the built-in set, NSX allows creation of custom roles tailored to specific operational requirements. Only an Enterprise Administrator can assign the role management permission to a custom role. NSX Federation extends RBAC to multi-site deployments, applying the same access control model across federated NSX instances. Principal identities, which are used for service-to-service authentication local to NSX, also support RBAC role assignment, so automated integrations operate under the same access control model as human users.

VCF Operations enforces RBAC through the assignment of service roles to users and groups. Administrators configure role-based permissions through the Roles tab under Infrastructure Operations, where individual permissions can be selected or deselected to define what each role is authorized to do. The System Administrator role includes rights covering approvals, audits, certificates, datastores, edge clusters, integrations, LDAP settings, namespaces, proxy rules, system settings, tokens, and truststore operations. Administrative operations such as password management require authentication with a user assigned the ADMIN role. VCF Operations also defines its own roles within vCenter, with privileges named using a convention that appends the role to the product name (such as VCF Operations ContentAdmin Role and VCF Operations PowerUser Role). The PowerUser role has privileges to perform the actions of the Administrator role except for user management and cluster management. A further restricted PowerUserMinusRemediation role excludes remediation actions in addition to those

limitations. A vCenter administrator assigns these roles to users, and VCF Operations maps vCenter users to the appropriate role.

vSAN supports RBAC and permissions management for authentication and authorization of storage operations. The vSAN Security Configuration Guide provides guidance on configuring these role-based controls for storage infrastructure.

VCF Automation governs access through multiple RBAC mechanisms at different scopes. At the organization level, rights bundles assign specific API permissions to roles including Organization Administrator, Organization Auditor, and Organization User. Group membership and role assignment are managed through the Access Control interface, and organization administrators can edit role assignments for groups at any time. At the project level, VCF Automation defines three distinct roles: administrators, members, and viewers, providing tiered access to project resources and operations. VCF Automation also governs blueprints, catalogs, content libraries, and custom entities through its role model. The Assembler Administrator role has read and write access to the entire user interface and API resources, while other roles have progressively narrower permissions.

For Kubernetes workloads running on VMware Kubernetes Service (VKS), VCF enforces RBAC through two complementary control layers. At the vSphere layer, vSphere Namespaces assign three permission roles: Owner (full control including namespace deletion), Can Edit (provisioning and operating workloads), and Can View (read-only access). At the Kubernetes layer, the Kubernetes RBAC authorization framework governs access to all API server requests through four core objects: Roles define permissions scoped to a single namespace, ClusterRoles define permissions applying cluster-wide, and RoleBindings and ClusterRoleBindings associate those roles with authenticated subjects such as users, groups, or ServiceAccounts. Permissions are purely additive with no deny rules, and administrators can restrict access to individual resource instances by name using the resourceNames list in role rules.

VKS clusters integrate with VCF SSO so that Kubernetes RoleBinding objects grant RBAC permissions directly to VCF SSO users and groups. This means the same identity provider that governs VMware vCenter access also governs Kubernetes cluster access, providing a consistent identity model across both the platform and workload layers. Cluster operators use kubectl or the Kubernetes API to assign role permissions to developers and other personas with defined responsibilities.

Kubernetes RBAC also governs ServiceAccounts, which provide discrete identities for pods and automation processes. This separation allows human access and workload access to be governed independently, with each scoped to the minimum permissions required for its function. ServiceAccounts follow the principle of least privilege by receiving only the minimum set of permissions required to function correctly, and RBAC should be applied to Secret objects to enforce least-privilege access to sensitive data stored within namespaces.

The Kubernetes RBAC API includes built-in controls against privilege escalation: the API prevents users from editing roles or role bindings to gain permissions beyond those they already hold, and this enforcement applies at the API level regardless of the authorization mode in use. Role-binding authority can be explicitly delegated by granting a user permission to perform the bind verb on a specific Role or ClusterRole, limiting the roles that identity can delegate to others.

In multi-tenant VKS deployments, RBAC is the primary mechanism for isolating tenants within a shared cluster. Administrators use Role and RoleBinding objects at the namespace level to restrict each tenant's access to its assigned namespaces, and ClusterRole and ClusterRoleBinding objects to control access to cluster-level resources, blocking unprivileged users from crossing tenant boundaries.

Supervisor services deployed on VKS clusters extend RBAC to their own access models. The Secret Store Supervisor Service enforces role-based access control across administrator, DevOps engineer, and application tenant roles, controlling who can manage and retrieve sensitive data. The Argo CD Supervisor Service implements RBAC through a configurable policy field using Casbin syntax, with the spec.rbac.policy setting defining role assignments and permission rules; policy rules (p rules) control account permissions including the ability to grant admin roles to specific local accounts, and group mappings (g rules) assign accounts to role groups.

VMware Private AI Services (PAIS) provides role-based access control scoped to its AI services and AI workload delivery components. The central mechanism is OIDC group-based authorization for PAIS. When activating PAIS in an organization

namespace, administrators populate the `authorizedGroups` setting with one or more OIDC group identifiers so that only users who belong to those groups can access the service. The OIDC configuration supports a configurable groups claim name through the `oidc-groups-claim` setting, with the groups claim carried in the Access Token and evaluated at access time. PAIS requires an OIDC provider configured as a public client application with Authorization Code and Refresh Token grant types, and it can be configured with one OIDC provider. Additional OAuth 2.0 client identifiers can be accepted by configuring Extra Audiences through the `oidc-extra-audiences` setting when the OIDC provider issues tokens for multiple audiences.

PAIS extends the same identity model to the Grafana observability platform used for PAIS metrics. Grafana role assignment is configured through the `grafana-oidc-role-mapping` property using an expression such as `contains(groups['*'], 'pais-access-group') && 'Admin' || 'Viewer'`, so OIDC group membership maps automatically to Grafana Admin or Viewer roles. PAIS uses the same OIDC provider for Grafana authentication that it uses for service access.

For machine learning model storage, the Model Gallery uses Harbor project access capabilities to restrict access to the sensitive data used to train and tune models. PAIS integrates with Harbor registries as the model storage backend and requires authentication and certificate-based trust for model retrieval. PAIS is compatible with OCI-compliant registries from other vendors when deployed in a disconnected or air-gapped environment, and the project-scoped access controls apply to the chosen registry.

Access to PAIS catalog items for GPU-accelerated VKS clusters and other AI workloads is governed through project-based permissions in VCF Automation. PAIS custom forms in blueprints can be modified to control user inputs at request time, scoping which configuration choices a requester can make when provisioning AI workloads. Knowledge Base data sources used by PAIS retrieval augmented generation require authenticated access to external repositories, including user name and password authentication for SharePoint On-Premises data sources and access keys with list and read permissions on the target bucket for Amazon S3 compatible stores. PAIS uses a CA trust bundle for secure communication with external services and databases.

These PAIS-specific controls operate at the AI services and workload layer. Access to the underlying compute, storage, and networking infrastructure is governed by platform-level RBAC in VCF, including VCF SSO and VMware vCenter role assignments, and database-level access for vector and operational data is governed by Data Services Manager. PAIS adds service-level and workload-level RBAC for AI-specific assets on top of the VCF platform foundation rather than replacing those platform controls.

VMware vDefend (Contributes)

VMware vDefend contributes to AAA governance through built-in controls in Security Services Platform (SSP) and through network-layer enforcement capabilities in the Distributed Firewall.

SSP implements authentication using local accounts or directory-managed accounts. The platform uses Authelia, an open-source authentication and authorization server that provides two-factor authentication (2FA) and single sign-on (SSO) capabilities, alongside an Authserver that handles authentication requests and manages credentials. For directory integration, SSP supports Active Directory over LDAP or OpenLDAP, with only one identity source configured at a time. These capabilities apply across both the SSP platform itself and its License Hub component.

For authorization, SSP ships with two predefined local user accounts that enforce separation of duties: an admin user with the Enterprise Admin role for full management access, and an audit user with the Auditor role for read-only access to APIs and services for system auditing. These accounts are present in the SSP platform, the SSP Installer, and License Hub. The audit user's password must meet required criteria and can be reset by the admin user through the User Management interface.

For auditing, SSP provides a purpose-built audit user account scoped to compliance review and system inspection. All access events to License Hub are logged in audit logs that are enabled by default and cannot be disabled, providing a persistent access record for that management component.

At the network enforcement layer, vDefend microsegmentation policies restrict which systems can reach AAA infrastructure such as identity providers, directory services, and authentication servers, reducing the exposure of those services to lateral movement. Identity Firewall (IDFW) extends enforcement by using Active Directory user and group membership directly as

the basis for firewall rule decisions. IDFW detects user logins by monitoring login events in domain controller event log servers, then applies security policies based on AD group membership. This allows network access rules to follow user identity across virtual desktops (VDI), Remote Desktop Sessions (RDSH), and physical machines. IDS/IPS profiles can detect attempts to exploit vulnerabilities in authentication services.

These controls do not replace organizational AAA governance policies or manage AAA solutions across the broader environment. They implement authentication, authorization, and audit mechanisms within the vDefend management layer and provide network-layer protection for AAA infrastructure that supports organizational governance objectives.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) implements authenticate, authorize, and audit (AAA) mechanisms for replication and recovery operations. Authentication uses VCF SSO. The PNR server acquires a holder-of-key SAML token from VCF SSO and presents it in a cryptographically signed envelope when establishing authenticated communication channels to remote services such as VMware vCenter. PNR uses service account authentication for server-to-vCenter communication, and a domain-level service account created by vCenter is used when PNR runs in an Enhanced Linked Mode environment. When connecting peer vCenter instances that reside in different or the same SSO domains, PNR also supports credential-based authentication. The PNR Appliance Management Interface requires authentication as the admin user for service management, network configuration, time zone settings, storage replication adapter configuration, and site unregistration workflows. The default admin password is set during initial deployment and is expected to be changed by the operator. PNR exposes Authentication APIs as part of its REST API gateway, including a REST endpoint to log out an authenticated session.

Authorization is enforced through PNR's privileges, roles, and permissions model. PNR performs operations using the user credentials supplied when the protected and recovery sites are connected, and permission checks apply at both sites for cross-site operations. The configuration import and export tool accepts the `--localAuthUseSA` and `--remoteAuthUseSA` parameters, which select whether a Service Account file is used for authentication to the local or remote site. PNR and later supports Service Account authentication for importing or exporting configuration data.

Audit logging records replication and recovery operations and security-relevant events. PNR records operational information in log files that do not contain private keys or passwords. Authorization errors and certificate verification errors are written with timestamps and component information to security-related log files for audit trail purposes. Replication lifecycle events generate audit log entries, for example the `AutoprotectEnabledRpEvent` entry that indicates Automatic Protection has been activated for a replication provider.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) implements role-based access control natively, with two defined role types that govern access to all data service resources. The DSM Admin role is a super-user role with full access to create, monitor, and manage all data services across the environment. The DSM User role is a restricted role that limits a user to viewing and managing only the data service deployments they own. This separation is enforced at the console level: the views and available actions in the DSM interface differ based on the assigned role, so users with the DSM User role cannot see or act on resources outside their own scope.

Access control is further refined through namespace scoping. DSM User role assignments can be restricted to one or more specific namespaces, limiting access to data services within those assigned namespaces only. Administrators can modify a user's assigned role and namespace access after initial provisioning. DSM namespaces enforce role-based access control that allows multiple users to work on data services within a shared namespace while maintaining appropriate permission boundaries between them.

DSM supports both local user accounts and directory service integration for identity management. Local users are created through the DSM UI, where administrators specify the user's role, email address, and password. For enterprise directory integration, DSM supports LDAPS-based authentication with Directory Service Group mapping, allowing administrators to assign users to either the DSM Admin or DSM User role based on their LDAP group membership. This group-based mapping is configured through the vSphere Client during DSM setup or through the DSM UI after deployment.

Access control extends to storage and database resources as well. DSM IAM policies for S3-compatible storage support granular access control through policy statements that allow specific S3 actions, including PutObject, GetObject, DeleteObject, and ListMultipartUploadParts. At the database level, PostgreSQL instances support the CREATE ROLE command to create database roles for LDAPS users with configurable login capabilities, and administrators can configure Host-Based Authentication (HBA) rules to restrict which clients and authentication methods may connect to a PostgreSQL instance. For SQL Server instances, DSM applies least-privilege access by granting the cluster administrator login restricted read-only privileges and specific ALTER privileges for server management and auditing, rather than full administrative access. Data service policies also support allowlist configuration to restrict users to selecting only from a specific set of approved parameters when provisioning databases.

The DSM Permissions view provides a centralized interface for administrators to create, monitor, and manage configured users. This view supports ongoing governance of who has access to what within the DSM environment, making it straightforward to audit and adjust role assignments as business needs change.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer (Avi) maintains its own administrative identity plane with mechanisms covering all three AAA elements: authentication, authorization, and audit. User accounts fall into two categories: local users and remote users. Remote users are authenticated through external AAA servers, with support for LDAP, TACACS+, and SAML-based authentication profiles. The product documentation recommends federated authentication as the preferred approach, delegating the authentication process to an organization's central identity provider rather than managing credentials locally within Avi.

For authorization, the Avi Controller evaluates authorization mapping rules on every user login, updating the user record with tenant and role pairs. Auth Mapping Profiles can map multiple user groups to different roles with tenant isolation, supporting both simple single-role assignments and multi-tenant configurations where a single user requires access across multiple administrative boundaries. The admin user is authorized and responsible for the highest-level configuration operations, including user creation and authorization and tenant management. The admin account is maintained as a locally authenticated account even in a system configured for remote authentication, providing a break-glass path for Controller access.

The Avi Controller License Hub provides dedicated role-based accounts for administration and auditing. The Admin account holds the enterprise_admin role with full access to deploy and manage security services, perform upgrades, and configure authentication and authorization. The Audit account holds the auditor role with full access to APIs and services for system auditing. LDAP can be configured as an identity provider for License Hub authentication, and the Admin user can reset the Audit user's password.

Avi also supports OAuth and OpenID Connect (OIDC) for client authentication at the application proxy layer. When configured, the Controller acts as a resource server and retrieves identity information from the OIDC UserInfo endpoint or from ID token claims, enabling per-user identity context to be associated with proxied application traffic. DataScript can check if a user ID is in an approved group list and redirect unauthenticated users to a login page, providing identity-based access control at the virtual service layer.

In the Avi for VCF Organization-Managed Mode, the organization administrator must be authenticated to edit Service Engine Groups and manage their own infrastructure configurations, reinforcing role-based access enforcement at the VCF integration layer.

The control asks whether the organization centrally manages AAA across its environment. Avi provides the mechanisms for its own administrative plane and supports integration with a central identity provider, but the organization must configure that integration, maintain the identity provider, and establish processes for reviewing audit log output.

Control Tenet 4

Access to resources is determined by dynamic policy—including the observable state of client identity, application/service, and the requesting asset—and may include other behavioral and environmental attributes. An organization protects resources by defining what resources it has, who its members are (or ability to authenticate users from a federated community), and what access to resources those members need. For zero trust, client identity can include the user account (or service identity) and any associated attributes assigned by the enterprise to that account or artifacts to authenticate automated tasks. Requesting asset state can include device characteristics such as software versions installed, network location, time/date of request, previously observed behavior, and installed credentials. Behavioral attributes include, but not limited to, automated subject analytics, device analytics, and measured deviations from observed usage patterns. Policy is the set of access rules based on attributes that an organization assigns to a subject, data asset, or application. Environmental attributes may include such factors as requestor network location, time, reported active attacks, etc. These rules and attributes are based on the needs of the business process and acceptable level of risk. Resource access and action permission policies can vary based on the sensitivity of the resource/data. Least privilege principles are applied to restrict both visibility and accessibility.

SCF Controls: CFG-08, DCH-01.2, DCH-01.4, DCH-13.3, DCH-14.2, DCH-24.1, DCH-25, DCH-25.1, END-01, IAC-01.2, IAC-03, IAC-04, IAC-05, IAC-05.2, IAC-08, IAC-09, IAC-13.2, IAC-15.1, MDM-09, MON-02.3, MON-02.4, MON-16, NET-02.3, NET-04, NET-04.1, NET-04.12, NET-04.7, NET-08.3, NET-08.4, NET-14.7

Aggregate Coverage: Meets

VCF (Meets)

VCF provides layered mechanisms to restrict privileged access to authorized organizational users through centralized authentication, role-based access control, explicit role assignment requirements, and organization-scoped permissions across all platform components.

VCF SSO and the VCF Identity Broker act as the centralized authentication boundary for the platform. All administrative access to VMware vCenter, NSX, VMware ESX, VCF Operations, VCF Automation, the Supervisor control plane, and VMware Kubernetes Service (VKS) clusters flows through VCF SSO, and administrators control which identity sources are configured. By federating VCF SSO with the organization's enterprise identity provider, access is limited to users who exist in the organization's directory. Users who are not part of a configured identity source cannot authenticate. However, authentication alone is insufficient to gain privileged access. VCF enforces a model where users without explicitly assigned roles cannot access component consoles with their enterprise credentials. An administrator must deliberately assign a role to each user before that user can interact with any VCF component.

Privileges in vCenter are fine-grained access controls that can be grouped into roles and then mapped to specific users or groups. The AuthorizationManager in vCenter allows or restricts access to specific server objects based on the permissions associated with each object, providing enforcement at the object level. If a predefined role does not match access requirements, administrators can define custom roles containing only the minimum set of required privileges. For example, custom roles can allow users to encrypt but not decrypt virtual machines, so that privileged operations are available only to those with a documented need. vCenter also provides a No Access role that explicitly denies access to a user or group, removing the assigned user's visibility into any objects. This can be applied to non-organizational accounts to remove their visibility and control over the environment.

Beyond the vSphere Client, the vCenter appliance exposes an Appliance Shell and an Appliance Management Interface, both of which require authentication as root or as a user with the super administrator appliance role. Access to the Bash shell from within the Appliance Shell is disabled by default for non-root users and can be enabled only by a super administrator using the `shell.set --enabled true` command, providing a distinct privileged boundary separate from vCenter's RBAC model.

Within the Consumption layer, Supervisor Services lifecycle operations require the Manage Supervisor Services privilege on the vCenter system where the service is registered; this applies to adding, activating, and deleting Supervisor Services and to installing the Supervisor Management Proxy. Access to Supervisor and VKS clusters as VCF SSO users requires sufficient role permissions on the relevant vSphere Namespace; the VCF CLI returns a Forbidden error when a user lacks the necessary permissions, providing a clear enforcement signal at the access boundary. vSphere Namespace permissions are assigned to VCF SSO users and groups through three role options: Can View, Can Edit, and Owner. The Owner role is available only with VCF SSO authentication, tying the highest namespace permission level directly to the organizational identity boundary. A VCF SSO user granted the Edit permission on a vSphere Namespace is automatically assigned the cluster-admin role for any VKS cluster deployed in that namespace, making namespace permission grants operations that must be managed carefully to avoid inadvertently elevating external or non-organizational accounts. For organizations connecting VKS clusters to external identity providers, access control can be configured at the provider level to restrict which users within the external organization are permitted to access VKS clusters, adding a pre-authentication gate before Kubernetes role assignments apply. SSH access to Supervisor control plane nodes requires root credentials via vCenter, gating that access behind the organizational identity boundary.

Inside VKS clusters, Kubernetes RBAC governs what authenticated users can do. The RBAC API restricts privilege escalation by requiring users to hold explicit permissions before they can create or update RoleBinding or ClusterRoleBinding objects; this enforcement is applied at the API level regardless of whether the RBAC authorizer is active. Users cannot grant themselves permissions they do not already possess. Service accounts are subject to the same RBAC framework and should be scoped to the minimum required permissions. The system:masters group should not be used in VKS cluster configurations because membership in that group bypasses all RBAC checks and grants unrestricted super-user access that cannot be revoked through normal RoleBinding or ClusterRoleBinding removal. The privileged Pod Security Admission (PSA) standard, which permits known privilege escalations, should not be used in namespaces serving multi-tenant workloads; namespaces that must allow privileged workloads should establish explicit access controls to restrict who can schedule them. Dynamic Resource Allocation APIs should be controlled through RBAC to restrict access based on user persona. Administrators should apply the least-privilege pattern even for administrative accounts, reserving elevated access for break-glass scenarios. When the requirePasswordOnSudo setting is configured on Supervisor, password entry is required before sudo administrative operations can run, adding an authentication step before privileged commands execute.

For organizations using VCF Automation, organization-specific roles can be assigned only to users who belong to the organization to which those roles are scoped. This architectural constraint directly restricts non-organizational users from receiving privileged roles within an organization's boundary. Organization users can use only those rights from their roles that are published to their organizations, further limiting privilege scope. Organization administrators can disable users and user groups to immediately deactivate their access and block login. The Organization Owner role can manage users within the organization portal but cannot access services without a separate service role, enforcing separation between user management and operational privileges. The Advanced Rights Bundle Mode allows administrators to control exactly which rights are available to each organization, limiting privilege creep. The accessControls API gives system administrators with the Manage General ACL right programmatic control over access control lists for fine-grained permission management.

In NSX, users without the Enterprise Administrator role cannot modify or delete protected objects owned by principal identities. Only users with the Enterprise Administrator role can modify or delete these objects, restricting privileged operations on protected configuration to a narrow set of authorized administrators.

VCF Operations implements role-based access control where users can only perform the actions that their assigned permissions allow. A vCenter user must have either the vCenter Admin role or a specific VCF Operations privilege, such as PowerUser assigned at the root level, to log in to VCF Operations. The administrators role in VCF Operations should be assigned only to specific users who require access to objects and actions across the entire environment.

VMware vDefend (Meets)

VMware vDefend (vDefend) enforces role-based access control across its security management interfaces to restrict access to firewall policy administration, threat analysis functions, and monitoring capabilities based on assigned user roles.

The vDefend distributed firewall (DFW) implements RBAC to control who can create or modify firewall rules, limiting policy changes to authorized personnel. Access to DFW monitoring features, including Firewall Insights, requires one of three designated roles: Enterprise Admin, Security Admin, or Security Operator. Rule Analysis operations within the platform are also role-gated across the five defined role types.

Security Services Platform (SSP) implements RBAC with five defined roles governing access to platform operations: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. Each role carries differentiated permissions; Full Access grants create, read, update, and delete capabilities, while Read-only access is available for monitoring-oriented roles such as Auditor and Support Bundle Collector. Role assignments can be applied to individual remote users or to remote user groups managed through a directory service, allowing administrators to align vDefend access with existing organizational structures. Multiple roles can be assigned to a single user or group to meet varying operational requirements. SSP's RBAC model also applies to License Hub operations, restricting licensing management actions to authorized roles.

Security Intelligence RBAC in 9.1 uses the same five-role model as SSP (Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector), aligning Security Intelligence access governance with SSP's permission model and providing consistent role boundaries across both the detection and platform layers.

For organizations using VCF Automation for vDefend firewall management, VCF Automation provides a dedicated Firewall category under RBAC rights, controlling access to the management and viewing of DFW rules, Tenant Gateway Firewall policy, VPC Gateway Firewall policy, and VPC Security Profiles. This allows organizations to scope firewall administration rights independently of other VCF Automation capabilities, supporting separation of duties between network automation and security policy management.

vDefend's RBAC controls complement the broader VCF RBAC model by restricting access to network security policy management independently of compute, storage, or platform configuration access. An administrator with VMware vCenter privileges does not automatically gain the ability to modify firewall rules or security analytics configurations unless explicitly granted the appropriate vDefend roles. This separation of duties between infrastructure administration and security policy management supports distinct team structures for network security management.

VCF Protection and Recovery (Contributes)

Protection and Recovery (PNR) implements role-based access control through purpose-built roles registered in VMware vCenter and through a multi-tenant administrative model for Protection and Recovery for VCF Automation. The SRM Administrator role allows users or user groups to perform all PNR configuration and administration operations. The Protection and Recovery Administrator role can be assigned to user groups to manage permissions. Default roles provide the privileges users require to manage protection groups and perform recoveries, while restricting access to resources belonging to other users.

For automatic protection of virtual machines within a protection group, administrators assign either the SrmAdministrator or SrmProtectionGroupsAdministrator role to the automatic protection user or user group. This scopes the protection actions performed on the user's behalf to the privileges of the assigned role.

Each role is a collection of privileges that defines the actions a user can perform on the protection and recovery site. A user can have at most one role on an object, but roles combine when the user belongs to multiple groups that all have roles on the object. PNR supports propagating roles to child objects in the inventory hierarchy, so administrators can extend privileges from parent objects such as folders to all virtual machines within them.

Protection and Recovery for VCF Automation introduces a multi-tenant role model with Provider Administrator, Organization Administrator, Project Administrator, and Project Advanced User. Each role has specific authorization levels for disaster recovery operations. Provider Administrators select which replication classes each Organization can use, restricting organizational access to specific recovery configurations. Organization Administrators manage the pairing of namespaces and assignment of replication classes within their tenancy.

Underlying directory services, authentication, and enterprise identity governance are provided by VCF SSO and the broader VCF platform. PNR consumes those identities and layers its protection and recovery roles on top of them.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) implements role-based access control natively, with two defined role types that govern access to all data service resources. The DSM Admin role is a super-user role with full access to create, monitor, and manage all data services across the environment. The DSM User role is a restricted role that limits a user to viewing and managing only the data service deployments they own. This separation is enforced at the console level: the views and available actions in the DSM interface differ based on the assigned role, so users with the DSM User role cannot see or act on resources outside their own scope.

Access control is further refined through namespace scoping. DSM User role assignments can be restricted to one or more specific namespaces, limiting access to data services within those assigned namespaces only. Administrators can modify a user's assigned role and namespace access after initial provisioning. DSM namespaces enforce role-based access control that allows multiple users to work on data services within a shared namespace while maintaining appropriate permission boundaries between them.

DSM supports both local user accounts and directory service integration for identity management. Local users are created through the DSM UI, where administrators specify the user's role, email address, and password. For enterprise directory integration, DSM supports LDAPS-based authentication with Directory Service Group mapping, allowing administrators to assign users to either the DSM Admin or DSM User role based on their LDAP group membership. This group-based mapping is configured through the vSphere Client during DSM setup or through the DSM UI after deployment.

Access control extends to storage and database resources as well. DSM IAM policies for S3-compatible storage support granular access control through policy statements that allow specific S3 actions, including PutObject, GetObject, DeleteObject, and ListMultipartUploadParts. At the database level, PostgreSQL instances support the CREATE ROLE command to create database roles for LDAPS users with configurable login capabilities, and administrators can configure Host-Based Authentication (HBA) rules to restrict which clients and authentication methods may connect to a PostgreSQL instance. For SQL Server instances, DSM applies least-privilege access by granting the cluster administrator login restricted read-only privileges and specific ALTER privileges for server management and auditing, rather than full administrative access. Data service policies also support allowlist configuration to restrict users to selecting only from a specific set of approved parameters when provisioning databases.

The DSM Permissions view provides a centralized interface for administrators to create, monitor, and manage configured users. This view supports ongoing governance of who has access to what within the DSM environment, making it straightforward to audit and adjust role assignments as business needs change.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer provides a native, multi-tiered Role-Based Access Control (RBAC) framework that governs all administrative access to the Avi Controller. At the base level, Avi roles assign one of four privilege types to each resource category: Write (full create, read, modify, and delete access), Read (view-only access to configuration, health, and analytics data without modification capability), Assorted (a mixed access level combining permissions across specific operations), and No Access (no access to the resource at all, including the inability to read or list it). Roles are combined with tenants to define the complete authorization settings for each user, scoping what resources a user can interact with and what actions they may take.

Beyond base privilege levels, the Extended Granular RBAC feature refines access using markers, which are key-value label pairs assigned to Avi objects. A role definition specifies that a user may access only objects bearing labels that match the role's marker set. The `allow_unlabelled_access` parameter controls whether a user can view objects that lack matching labels, allowing administrators to restrict visibility to labeled objects only. Label groups can be associated with tenants to enforce label-based access policies across the tenant boundary. Multiple label values can be mapped to a single key, enabling flexible classification schemes. This mechanism enables resource-level scoping across tenants and teams: for example, restricting a

group of operators to only the virtual services labeled with their team's identifier, without granting visibility into other teams' objects.

At the finest granularity, Avi implements sub-resource (field-level) RBAC, which scopes which specific fields within a configuration object a given user is authorized to modify. Sub-resource definitions can be combined so that a user can configure multiple fields or features within a single object while remaining restricted from updating others. Label-based permissions for cloud objects extend this field-level control to infrastructure resources managed by the Avi Controller. Virtual service configuration exposes RBAC directly: the RBAC tab in the Virtual Service advanced setup provides label-based access control for health monitors and associated objects, extending role enforcement down to individual service configuration items.

For GSLB deployments, the Avi Controller enforces RBAC through role references such as `Gslb_Group_Enabled` and `Gslb_Health_Monitor` that can be assigned to user accounts with tenant-level scope. These role references apply to follower sites configured with federated JWT profiles, scoping which accounts can modify GSLB configuration.

The Avi Controller applies RBAC within the License Hub, limiting which users can perform specific actions based on their assigned role.

For deployments using the Avi Kubernetes Operator (AKO), the Avi Controller implements RBAC by assigning tenants and roles to user accounts at the Kubernetes or OpenShift cluster level. AKO Custom Resource Definitions (CRDs) can leverage Kubernetes RBAC policies to restrict which user groups can configure routing rules, extending the Controller's authorization model into the Kubernetes control plane.

For deployments on Microsoft Azure, Avi integrates with Azure IAM to control which Azure identities have access to Avi Load Balancer resources hosted in Azure. Administrators can use built-in Azure roles such as Reader (read-only access) or Owner (full access), or define custom roles for finer control over specific resources.

RBAC configuration is managed through the Users section of the Avi Controller UI. Roles are defined per resource type and then assigned to users within a tenant. Extended Granular RBAC markers are attached to individual Avi objects (virtual services, pools, health monitors, and others) and referenced in the role definition. Sub-resource RBAC is configured as part of the Extended Granular RBAC object, combining field-level restrictions as needed.

Control Tenet 5

The enterprise monitors and measures the integrity and security posture of all owned and associated assets. No asset is inherently trusted. The enterprise evaluates the security posture of the asset when evaluating a resource request. An enterprise implementing a ZTA should establish a continuous diagnostics and mitigation (CDM) or similar system to monitor the state of devices and applications and should apply patches/fixes as needed. Assets that are discovered to be subverted, have known vulnerabilities, and/or are not managed by the enterprise may be treated differently (including denial of all connections to enterprise resources) than devices owned by or associated with the enterprise that are deemed to be in their most secure state. This may also apply to associated devices (e.g., personally owned devices) that may be allowed to access some resources but not others. This, too, requires a robust monitoring and reporting system in place to provide actionable data about the current state of enterprise resources.

SCF Controls: AST-01, AST-02.2, CFG-01, CFG-02, CFG-02.1, CFG-02.2, CFG-02.7, CFG-02.8, CFG-06, CFG-06.1, CHG-01, CHG-02, CHG-02.1, CHG-02.4, DCH-13.1, MON-01, MON-01.2, MON-02, MON-02.1, MON-02.2, MON-02.3, NET-01.1, NET-08.3, NET-08.4, NET-14.1, NET-14.7

Aggregate Coverage: Meets

VCF (Meets)

VCF provides several foundational capabilities that support a Zero Trust Architecture approach, though a complete ZTA implementation requires organizational policies, identity governance processes, continuous verification mechanisms, and additional tooling beyond what VCF delivers on its own.

VCF enforces authentication as a prerequisite to all access. The platform's authentication framework determines whether users are who they claim to be through credentials including smart cards, usernames, and passwords. VCF SSO integrates with the VCF Identity Broker to provide centralized authentication for VCF components, with support for identity provider federation to enterprise directories such as Active Directory Federation Services. Federating vCenter to an enterprise identity provider provides flexible options such as multi-factor authentication. OAuth 2.0 support allows information exchange among web services without exposing sensitive data such as usernames and passwords, reducing credential exposure during authentication flows. NSX network devices require authentication prior to establishing any management connection for administrative access, and all administrative accounts must be password protected. VMware ESX and vCenter systems restrict connections to authenticated users and they can access only those objects for which they have the required privileges and are authorized to use or view. Direct access to the ESX host console can be restricted to prevent administrators from overriding policy enforcement, and ESX supports configuration of users who can override lockdown mode and access the DCUI. For Windows virtual machines, vSphere Virtualization-based Security supports Credential Guard, which isolates and hardens key system and user secrets in the guest operating system against compromise. At the workload consumption layer, VMware Kubernetes Service (VKS) clusters support multiple authentication mechanisms for the Kubernetes API server, including OIDC federation with VCF SSO, X.509 client certificates, service account tokens, and webhook token authentication. Namespace-level access in VKS follows the same VCF SSO identity model as the broader vSphere platform. VKS implements a zero-trust token validation posture for external integrations such as AWS IRSA, trusting tokens only when issuer, signature, audience, and subject conditions are verified. Kubernetes guidance recommends enabling as few authentication mechanisms as necessary to simplify user management and prevent retained access through unused pathways, and it recommends setting short certificate lifetimes with automated rotation to limit the window of opportunity for credential misuse.

Once authenticated, VCF applies authorization controls that restrict what each principal can do. The vCenter AuthorizationManager controls access to specific server objects based on the permissions associated with each object. Authenticated users can view objects or invoke operations on the server only when the permissions associated with their account allow it. Administrators can create, modify, and manage roles and permissions through the AuthorizationManager, enabling granular role-based access control across the vSphere environment. The CloudAdmin role restricts access to

platform-level operations, and the No Cryptography Administrator system role supports all Administrator privileges except for Cryptographic Operations privileges, allowing organizations to separate encryption key management from general administration. You can clone the No Cryptography Administrator role and create custom roles with only some of the Cryptographic Operations privileges to further limit what users can do. NSX provides granular role separation within the VPC scope, where you can assign VPC Admin, Network Admin, Security Admin, Network Operator, and Security Operator roles. A VPC Admin has full access to all networking and security objects inside an NSX VPC, while other roles provide narrower access. This "authenticate first, then authorize" model aligns with core ZTA principles of never granting implicit trust. For containerized workloads, Kubernetes RBAC provides Role, ClusterRole, RoleBinding, and ClusterRoleBinding objects that define what each authenticated identity may perform at the namespace or cluster level. Least-privileged access applies even to administrators; elevated access is reserved for break-glass scenarios while standard operations use narrower roles. Authorization webhooks support fine-grained, attribute-based authorization decisions by passing field and label selector information to the webhook, enabling per-resource access control based on object attributes such as node name and labels. Dynamic Resource Allocation APIs carry elevated privilege implications and should be controlled using RBAC to restrict access based on user persona. Pod Security Admission enforces workload security profiles at the namespace level, with Baseline and Restricted profiles limiting privilege escalation, host namespace access, and container capabilities. Security contexts allow administrators to require that containers run as non-root users, drop Linux capabilities, apply seccomp profiles, or use AppArmor to restrict system call access at runtime. Cluster administrators can create custom pod security policies beyond the platform defaults and bind them to specific users, applying different trust levels to different teams or namespaces. Argo CD, available as a standard package for VKS clusters, supports local account authentication backed by global RBAC policies that define access control through policy rules and group mappings, extending authenticated and authorized access controls to the continuous delivery pipeline. Harbor, also deployable as a VKS standard package, enforces role-based access control for artifact management, requiring authentication and authorization before users can pull or push container images and charts.

Solution-to-solution communication within VCF uses certificate-based trust rather than passwords. VCF Automation establishes trust relationships with servers by verifying and trusting certificate information for SSL communication. When a client receives an element from VCF Operations, it verifies the server identity and decides whether to trust the signature before proceeding. Mutual TLS authentication based on self-signed or CA certificates is required between hosts and the NSX Central Control Plane. The VCF Identity Broker provides a centralized authentication source for VCF components, and vCenter and NSX components connect to it for SSO-based access. This certificate-based trust model means that VCF's own internal communications follow a verify-then-trust pattern rather than assuming trust based on network location. At the consumption layer, the Secret Store Supervisor Service enforces RBAC for administrators, DevOps engineers, and application tenants managing and distributing sensitive data, providing controlled access to credentials without broad exposure. Kubernetes guidance recommends using short-lived secrets to limit the impact of unintentional credential exposure, and audit rules can alert on anomalous access patterns such as concurrent reading of multiple secrets by a single user. Scoping IAM role trust policies to specific service accounts and namespaces enforces least-privilege at the credential level within VKS deployments.

VCF's networking layer provides segmentation capabilities that support ZTA network isolation. NSX projects enable multi-tenancy by isolating security and networking objects across tenants within a single NSX deployment, so that each tenant's resources are separated from others. NSX VPC enables tenant-level isolation of both networking and security objects, with each VPC operating as a self-contained boundary. Security groups can further define isolation settings for on-demand private or outbound networks. Kubernetes network policies can be imported to NSX and converted to vDefend policies, extending consistent security boundaries to containerized workloads alongside traditional VMs. The vSphere Distributed Services Engine supports zero-trust security by offloading network security processing to a dedicated data processing unit, separating security enforcement from the host operating system. These segmentation capabilities allow organizations to build network architectures where lateral movement between zones requires explicit authorization. VMware vDefend extends this foundation with microsegmentation and identity-based firewall rules that integrate with Active Directory for user-aware access enforcement at the workload level. At the Kubernetes networking layer, Cilium, a supported CNI option, enforces network policies at layers three through seven using an identity-based security model that is decoupled from network addressing, allowing policy to follow workload identity rather than IP addresses. Istio's ambient data plane mode, available as a standard package for VKS clusters, uses a per-node ztunnel component to provide mutual authentication and encrypted transport for east-west traffic within the mesh, extending verify-before-trust semantics to workload-to-workload communication. Service

meshes operating at layer seven can enforce policies based on workload identity and frequently provide mutual TLS to maintain data confidentiality even in the presence of a compromised node.

VCF Operations provides visibility into platform activities through audit event collection. VCF Operations reports on authentication and security-related audit events, and each audit event has a detailed view containing information that helps analyze events in the virtual infrastructure for suspicious user actions or system issues. This supports the continuous monitoring aspect of zero trust by correlating authentication events, configuration changes, and related activity across the environment.

To realize a full Zero Trust Architecture, organizations need to supplement VCF's technical controls with an overarching ZTA policy framework that defines trust boundaries, continuous verification requirements, and least-privilege access principles across all systems. Device posture assessment, continuous session monitoring, and adaptive access policies based on risk signals typically require integration with identity governance platforms and security analytics tools beyond what VCF provides natively.

Zero Trust Architecture requires that every user and device be authenticated and authorized before accessing data or resources, with no implicit trust based on network location or prior access. VMware Private AI Services (PAIS) implements authentication and access control mechanisms across its AI services layer that support this model.

PAIS enforces access through OIDC-based group membership. The PAISConfiguration custom resource requires an issuer URL, a client ID, and scopes including openid, groups, and offline_access, with a groups claim carried in the access token. Access is restricted to user accounts that belong to authorized groups configured via the authorizedGroups setting, and users outside those groups are denied access regardless of network position. Communication with the OIDC provider is required over HTTPS, and an issuer certificate must be present for that provider. PAIS supports a single OIDC provider per configuration.

Certificate-based mutual trust is enforced across PAIS component connections. CA trust bundles are required for the OIDC provider, the Harbor registry hosting the model gallery, content management systems used as data sources in Data Indexing and Retrieval, MCP servers providing tools to models, and the pgvector database server storing vector embeddings for Knowledge Bases. Trust bundles are configured through VCF Automation by uploading a certificate file or referencing a ConfigMap in the namespace, and the worker.clientTls.caBundleRefs setting controls the CA bundle references used for client TLS connections. Separate trust bundles per application are recommended, with refreshes required before certificate expiration.

At the model and data plane, the Model Gallery uses Harbor project access controls to restrict access to sensitive model training and tuning data, and model endpoints authenticate to private registries through a harbor-pull-secret-readonly secret. Remote MCP servers connected to PAIS can use static authentication tokens, and Knowledge Base data sources such as Confluence and SharePoint require a user name and password or a personal access token configured per administrator settings. Grafana dashboards visualizing PAIS metrics also authenticate through the OIDC provider, extending OIDC-mediated access into the observability path.

VMware vDefend (Meets)

VMware vDefend (vDefend) is a foundational technology for implementing Zero Trust Architecture (ZTA) within VCF. While a full ZTA implementation also requires identity governance, organizational policy, and continuous verification processes beyond any single product, vDefend provides the network security enforcement layer that treats all east-west traffic as untrusted by default and enforces explicit authorization at the workload level.

vDefend enforces security policies at the vNIC level, meaning every virtual machine's network interface is individually firewalled regardless of its network location. Network location does not confer trust, and every communication must be explicitly permitted. The default-deny posture of Distributed Firewall rules means workloads cannot communicate unless a policy explicitly allows that traffic, reducing the risk of lateral movement by treating all internal traffic as untrusted. The Distributed Firewall Connectivity Strategy feature simplifies micro-segmentation rule creation for applications, lowering the operational barrier to deploying a Zero Trust model.

Security Services Platform provides a guided security segmentation journey that walks administrators through a staged implementation of zero trust using vDefend. This workflow moves from broad infrastructure segmentation through environment-level isolation to fine-grained application ringfencing, where policies are defined down to the individual application tier. Security Intelligence complements this journey by providing the visibility and analytics needed to understand application security policy requirements, supporting identification of gaps in the zero trust posture. Security Services Platform generates Security Segmentation Reports and Blast Radius Reports that break down at-risk workloads, communication chains, and network flows to support Zero Trust journey planning. Security Services Platform also enforces role-based access control by assigning platform roles to remote users and user groups, subjecting access to the security management plane to the same authorization principles that govern workload-level policies.

vDefend Identity Firewall extends the zero trust model beyond IP-based rules by integrating with Active Directory to create firewall rules based on user identity and group membership. Administrators can define policies that grant or restrict access based on authenticated user identity rather than IP address. Identity Firewall rules can specify source users or groups, destination resources, services, and context profiles to allow or deny traffic based on user identity. Identity Firewall also supports simultaneous logins by multiple users on the same virtual machine, with each user's application access controlled based on their role requirements. Administrators can use Identity Firewall with Remote Desktop Session Host to create Active Directory security groups that allow or deny users access to application servers based on their assigned role. Identity Firewall supports two login detection methods: Event Log Scraper (ELS), which reads Windows security event logs from domain controllers, and Guest Introspection, which captures authentication events from within the guest operating system. The choice between these methods depends on the workload type and deployment environment.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides monitoring capabilities specific to the disaster recovery domain and integrates with the broader VCF monitoring ecosystem through dedicated Protection and Recovery dashboards in VCF Operations. VCF Operations collects configuration, component health, and usage information from protection and recovery servers and site pairs, presenting this through an overview dashboard that displays all site pairs, configurations, health scores, and protection and recoverability status for sites and virtual machines. PNR provides default health alerts for protection groups, recovery plans, cloud file systems, recovery SDDCs, and protected sites through VCF Operations, and the dashboards surface alerts informing administrators about configurations and deployments that require attention. Separate dashboard views cover vSAN Snapshots and Replication monitoring, and an Inventory view provides health status, metrics, alerts, and network topology for all monitored objects.

Within its own domain, PNR provides event logging and configurable alarms for replication and recovery operations. Administrators can create alarms that trigger on specified event conditions, with support for email notifications, SNMP traps, or script execution in response. PNR monitors connections between sites by sending periodic ping requests, logs connection check events, and generates alarms when broken connections are detected. The alarm system generates warning-level alerts for expired snapshot schedules, replication errors such as missing VMs, and connectivity issues with protected and target sites. PNR also monitors resource consumption on the Protection and Recovery Server host and raises alarms when configurable resource thresholds are reached.

PNR includes a health monitoring service that checks each health finding every five minutes and records a timestamp at each check. Health findings are tracked with status history that can be reviewed over configurable time periods, defaulting to a 24-hour window. The Protection and Recovery Appliance supports syslog forwarding to a remote syslog server for log analysis and centralized monitoring, allowing appliance-level events to flow into existing log management infrastructure.

The Clean Room Orchestrator, part of PNR's Cyber Recovery capabilities, supports monitoring of clean room events, tasks, and alarms for recovery operations. Clean Room Orchestrator can forward events to VCF Operations, Microsoft Sentinel, or Splunk Cloud for centralized monitoring, supporting organizations that require DR event data to flow into enterprise SIEM and log management platforms as part of a broader monitoring strategy. The Clean Room Orchestrator integrates with endpoint detection and response tools, including CrowdStrike and Carbon Black sensor appliances, for threat detection within isolated recovery environments.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to enterprise-wide monitoring controls through a layered set of observability capabilities covering database health, infrastructure compliance, and event-driven alerting.

DSM provides a built-in monitoring framework that tracks database instance health across multiple dimensions. From the Monitoring tab in the DSM UI or the vSphere Client, administrators and authorized users can view real-time and historical metrics for database VMs, including CPU Health, Data Disk Health, System Disk Health, Max Connections, Active Connections, Write Throughput, Read Throughput, Thread Resource Utilization, Slow Queries per Second, InnoDB Buffer Usage, and InnoDB Reads and Writes. The Monitoring page defaults to the last three hours of aggregated metric data, with the time range adjustable through the Time Range Last dropdown. This visibility supports detection of resource contention, performance degradation, and connectivity anomalies at the database layer.

DSM's alert framework provides configurable thresholds for warning and critical conditions on key health indicators. Administrators and users can set separate warning and critical thresholds for CPU Health, Data Disk Health, System Disk Health, and Max Connections parameters. When thresholds are exceeded, DSM generates typed alerts such as Database Engine Health, Custom Config Health, and Backup Storage Health alerts. DSM monitors database replication status and raises an alert when a secondary database is not replicating data from the primary. DSM also raises an alert when metrics are no longer being received from a cluster, supporting detection of monitoring gaps. Alerts can be activated or deactivated per data service through the "Enable Alerts for DB Alert" setting, providing granular control over which databases are subject to active alerting. For each alert, DSM provides mitigation suggestions to help administrators resolve issues without disrupting database services.

In addition to database-level alerts, DSM generates global infrastructure alerts that surface vCenter integration and infrastructure policy issues. These include `INFRASTRUCTURE_POLICY_VC_ALARMS`, raised when vCenter resource alarms are active; `INFRASTRUCTURE_POLICY_CLUSTER_COMPLIANT` and `INVALID_SUPERVISOR_INFRASTRUCTURE_POLICY_STATUS`, which reflect cluster compliance state; `VCENTER_CONNECTIVITY`, raised when vCenter connectivity fails and triggering troubleshooting steps that include verifying connectivity and checking authentication logs; and `LicensingNotUpdated` and `vCenterBinding API status` alerts that surface license and API integration conditions. A Global Alerts page in the DSM UI provides a centralized view of these alerts during and after installation and ongoing operation.

In 9.1, DSM integrates with VCF Operations to extend observability beyond the DSM UI. When configured, VCF Operations automatically discovers and monitors PostgreSQL and MySQL clusters in the Ready state and displays a Data Services View dashboard showing active alerts and inventory items. VCF Operations presents performance data across three levels: cluster-level for overall health, node-level for infrastructure resource use, and database-level for KPIs including Active Connections, Commits, Rollbacks, and Deadlocks. This integration requires configuring the connection between DSM and VCF Operations before use.

DSM also adds SQL Server as a supported database type, with dedicated monitoring through an integrated InfluxDB instance and Telegraf agents deployed across the provider appliance and SQL Server workload clusters. The monitoring framework supports metrics-based and status-condition-based alerts for SQL Server, covering database engine degradation, non-operational status, and automated or transaction log backup failure conditions.

DSM supports event notification to external systems through a webhook integration. Webhooks transmit alert notifications containing the triggered date, triggered time, triggered user email, task status, previous status, and task type. This allows DSM alerts to feed into centralized monitoring or incident management platforms maintained by the organization. DSM generates plug-in registration logs that administrators can review for vCenter connectivity errors, and DSM's troubleshooting guidance directs administrators to review active vCenter infrastructure alarms and resolve underlying issues identified through the alert system.

Enterprise-wide monitoring requires organizational decisions about monitoring architecture, log aggregation platforms, alerting policies, and operational response procedures that lie outside DSM's scope. DSM provides the data and integration

points; the organization must determine how those signals are collected, correlated, and acted upon across the broader environment.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer contributes to Zero Trust Architecture by enforcing authentication and authorization at the application delivery layer before client requests reach protected workloads. Avi's SSO Policy, configured per virtual service, supports Authentication Rules and Authorization Rules that validate JSON Web Tokens, OAuth 2.0 access tokens, and OIDC claims on every incoming request. Clients that present invalid or absent credentials are denied access before any request is forwarded to the backend resource. This per-virtual-service enforcement model means each application can independently require successful authentication as a condition of access.

Auth Mapping Profiles extend this authentication model into the Avi Controller's administrative plane. These profiles map authenticated user identities, including identities sourced from LDAP, SAML, or other external directory services, to specific tenants and roles with varying permission levels. Auth Mapping rules can be configured to deny all privileges to specific users, blocking them from obtaining any role or tenant assignment on login. When remote authentication is configured, administrators can independently enable or disable local user login, supporting stricter authentication policy enforcement. A user without a matching rule in the Auth Mapping Profile receives no privileges on login. Auth Mapping Profiles should be configured to enforce tenant isolation except for designated super users who require cross-tenant access.

At the management plane, administrators can restrict the source IP address ranges permitted to reach the Avi Controller and enforce strong password requirements. User Account Lockout is implemented on the Controller as a mechanism that blocks access after repeated failed authentication attempts. User accounts can be scoped to specific tenants and granted different roles within each tenant, limiting the blast radius of a compromised credential. HTTP security policies attached to virtual services are configurable to meet the security requirements applicable to each deployed application.

In VCF-integrated deployments, the Avi PKI Profile contains the list of Trusted Authorities allowed to sign client certificates and can be used to implement Zero Trust security between the server and the client. This certificate-based mechanism supports mutual authentication at the application delivery tier, complementing token-based authentication for workloads that rely on client certificate validation rather than OAuth or OIDC flows.

Full Zero Trust Architecture across a VCF environment requires capabilities beyond what Avi provides at the application delivery tier. Network-layer microsegmentation between workloads is provided by VMware vDefend, which is a separate product. OAuth, OIDC, and SAML federation require an external identity provider. The organizational policies that govern how authentication is enforced for all users and all devices must be defined and maintained by the organization; Avi provides the enforcement point for application traffic but does not itself constitute a complete ZTA implementation.

Control Tenet 6

All resource authentication and authorization are dynamic and strictly enforced before access is allowed. This is a constant cycle of obtaining access, scanning and assessing threats, adapting, and continually reevaluating trust in ongoing communication. An enterprise implementing a ZTA would be expected to have Identity, Credential, and Access Management (ICAM) and asset management systems in place. This includes the use of multifactor authentication (MFA) for access to some or all enterprise resources. Continual monitoring with possible reauthentication and reauthorization occurs throughout user transactions, as defined and enforced by policy (e.g., time-based, new resource requested, resource modification, anomalous subject activity detected) that strives to achieve a balance of security, availability, usability, and cost-efficiency.

SCF Controls: AST-02.2, AST-02.5, AST-02.9, IAC-01, IAC-01.2, IAC-06, MON-01, NET-01.1

Aggregate Coverage: Meets

VCF (Meets)

VCF provides built-in Authenticate, Authorize, and Audit (AAA) capabilities across its component stack, giving organizations a strong technical foundation for governing AAA within the platform.

For authentication, VCF SSO is the centralized identity broker. VMware vCenter can be federated with an external enterprise identity provider, which handles authentication in a federated model and enables flexible options such as multifactor authentication, automatic user registration, and termination of users across services. Named external identity providers supported for vCenter federation include Okta, with provider-specific configuration procedures available for each. NSX Manager supports local authentication, LDAP authentication, and OIDC authentication with configurable identity provider selection. VCF Automation allows organizations to define a shared identity provider and authenticate users through configurable authentication mechanisms, including redirections to external identity providers. The Identity API in VCF Automation provides programmatic management of authentication and authorization providers. The vCenter Client Credentials grant type also allows application-to-identity-provider authentication without a human user present, supporting machine-to-machine authentication scenarios. VMware ESX and vCenter validate user credentials against configured identity stores.

At the Kubernetes consumption layer, VMware Kubernetes Service (VKS) clusters support two authentication methods: VCF SSO and OIDC-compliant external identity providers. Administrators register an external provider by configuring the identity provider issuer URL, client credentials, and certificate authority through the Supervisor, enabling providers such as Okta. DevOps users then authenticate to the cluster using their identity provider credentials, keeping cluster authentication federated to a centrally managed identity store rather than relying on cluster-local accounts. Kubernetes hardening guidance recommends external authentication sources such as OIDC for production clusters with multiple users accessing the Kubernetes API directly. OIDC authentication is distributed to developer workstations through kubeconfig files, and custom ClusterClass configurations can be used to authenticate developers using existing corporate identity systems. Argo CD, when deployed as a Supervisor Service, supports PKCE-enabled OIDC authentication through the enablePKCEAuthentication field in the spec.oidc configuration, extending federated identity management to continuous delivery workflows. Infrastructure credentials, including service account tokens, can be configured to use short-lived certificates with automated rotation.

For authorization, VCF implements a permissions-based model across its components. Authenticated users on VMware ESX and vCenter can view objects or invoke operations depending on the permissions associated with their account. The vCenter authorization model provides consistent security control regardless of how users connect to the environment. NSX authentication best practices include defining access controls based on user roles and permissions and integrating with identity providers.

At the Kubernetes layer, the Supervisor exposes the full Kubernetes RBAC model through Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings, which control what authenticated principals can do within a cluster or namespace. The Node

authorizer supports TokenReviews and SubjectAccessReviews for delegated authentication and authorization checks. IAM role trust policies can be scoped to specific service accounts and namespaces to enforce least privilege across workloads. Kubernetes service accounts provide identity for Pods, allowing security software to group Pods into distinct security contexts. The Secret Store Supervisor Service enforces role-based access control for administrators, DevOps engineers, and application tenants managing and distributing sensitive data. Harbor Registry, deployable as a standard package on VKS clusters, secures container artifacts with policies and role-based access control, and its administrative interface allows administrators to verify authentication and access control configurations.

Audit capabilities are built into the platform at multiple levels. All API calls to NSX Manager are subject to authentication and authorization and generate audit logs. NSX supports audit data generation as a security functional requirement. NSX Manager and NSX Edge both include a dedicated audit role with separate credentials. The NSX Manager audit user has read-only privileges to the NSX environment and is not active by default; it must be explicitly activated after installation by an admin through the CLI. This separation of the audit role from administrative roles supports segregation of duties for audit functions. Within VCF SSO, NSX-related audit access is controlled through the NsxAuditors group, alongside NsxAdministrators and NsxViAdministrators, providing structured group-based assignments for NSX roles within the identity provider. NSX Manager exposes API endpoints (/api/v1/node/aaa/auth-policy and related paths) that return authentication policy settings, allowing administrators to validate authentication configuration across nodes programmatically. VCF Operations generates audit events across categories including access, access control, account management, configuration, data access, network, notification, permissions, session, system, policy, and firewall actions. These audit events are accessible through the Security menu and can be filtered, searched, and reviewed in detail.

The Kubernetes API server includes built-in audit logging. Audit events include an authenticationMetadata object that records how each request was authenticated, and when a request uses constrained impersonation the event includes an impersonationConstraint field that records which constrained impersonation verb authorized the request. Audit annotations capture authorization.k8s.io/decision and authorization.k8s.io/reason, recording authorization outcomes and their justifications in the audit log. ValidatingAdmissionPolicy objects emit audit annotations constructed from the policy name and a qualified key, with the annotation key included in the audit event, giving administrators a policy-level audit trail for admission control decisions. Separating service account creation from human user onboarding makes it easier to maintain distinct audit strategies for workloads and individuals.

Organizations looking to govern AAA within VCF should configure identity provider federation for vCenter and NSX Manager to centralize authentication through their enterprise identity provider. At the Kubernetes layer, configuring OIDC on VKS clusters and registering the same enterprise identity provider keeps workload cluster authentication aligned with the platform's identity governance. Enabling the NSX audit user and configuring audit logging across all components, including the Kubernetes API server, provides the audit leg of the AAA triad. The platform's support for multiple authentication methods (local, LDAP, OIDC) and its role-based authorization model give administrators the technical controls needed to enforce AAA policies. However, the governance policies themselves, including which AAA solutions to use, how to review and approve AAA configurations, and how to handle AAA for external service providers, must be established and maintained as organizational processes outside the platform.

VMware Private AI Services (PAIS) provides authentication and authorization mechanisms for its AI-specific services that organizations integrate into a broader AAA governance framework.

PAIS authentication uses OIDC. During service activation, an administrator configures the OIDC issuer URL, the client ID (pais-authentication-id), and the required scopes (openid, groups, offline_access). The configuration also accepts the OIDC issuer certificate and supports an Extra Audiences setting that allows PAIS to accept access tokens minted for additional OAuth 2.0 clients when the OIDC provider requires it. PAIS requires HTTPS-based communication for the OIDC integration, and activation must be coordinated with the OIDC provider administrator to establish the identity and access management relationship.

Access to PAIS is governed by the authorizedGroups setting, which restricts service access to user accounts that are members of specified OIDC groups (for example group-for-pais-access-01). Group-based authorization routes identity decisions made in the OIDC provider directly into PAIS access control without separate per-service user provisioning.

PAIS supports CA trust bundle management to establish certificate-validated communication with the OIDC provider, Harbor registries, content management systems, and external knowledge base sources. The Grafana observability integration uses OIDC for metrics visualization access and should enable PKCE and refresh tokens for its own authentication flow. Harbor registry access uses credential-based authentication via oras login for artifact push and model pull operations, and PAIS is compatible with OCI-compliant registries from other vendors. Knowledge Bases that ingest from Confluence authenticate using either a username and password or a personal access token. Remote MCP servers connected to PAIS can optionally use static authentication tokens. Air-gapped deployments require the self-hosted registry location and login credentials when the registry requires authentication.

Identity and access management for PAIS must be configured in coordination with an external OIDC provider administrator. PAIS provides the integration hooks and access enforcement mechanisms; the OIDC provider itself, including group lifecycle management and policy enforcement, is operated and governed separately by the organization.

VMware vDefend (Contributes)

VMware vDefend contributes to identity and access management by providing identity-aware network enforcement through Identity Firewall, which integrates with Active Directory to apply firewall policy based on authenticated user identity rather than IP address alone. Identity Firewall supports assigning Active Directory users and groups as source criteria in both distributed firewall rules and gateway firewall rules, applying to tier-0 and tier-1 gateways. This allows organizations to enforce network access policy by user or group membership rather than relying solely on IP-based controls.

Within its management plane, the Security Services Platform implements role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. These roles govern access to security policy management, analytics, incident response, and diagnostic functions across the platform. Network Detection and Response enforces the same five-role RBAC model for triage operations such as viewing detections and campaigns, and for configuration operations including SIEM integration management. For authentication, the Security Services Platform supports Active Directory and OpenLDAP as external identity sources, with one identity source configurable at a time. The License Hub integrates with external identity providers to store and manage user and group information for access delegation.

Centralized IAM for organizational users, including VCF SSO, MFA, and directory lifecycle management, is handled by VCF and falls outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) implements authenticate, authorize, and audit (AAA) mechanisms for replication and recovery operations. Authentication uses VCF SSO. The PNR server acquires a holder-of-key SAML token from VCF SSO and presents it in a cryptographically signed envelope when establishing authenticated communication channels to remote services such as VMware vCenter. PNR uses service account authentication for server-to-vCenter communication, and a domain-level service account created by vCenter is used when PNR runs in an Enhanced Linked Mode environment. When connecting peer vCenter instances that reside in different or the same SSO domains, PNR also supports credential-based authentication. The PNR Appliance Management Interface requires authentication as the admin user for service management, network configuration, time zone settings, storage replication adapter configuration, and site unregistration workflows. The default admin password is set during initial deployment and is expected to be changed by the operator. PNR exposes Authentication APIs as part of its REST API gateway, including a REST endpoint to log out an authenticated session.

Authorization is enforced through PNR's privileges, roles, and permissions model. PNR performs operations using the user credentials supplied when the protected and recovery sites are connected, and permission checks apply at both sites for cross-site operations. The configuration import and export tool accepts the `--localAuthUseSA` and `--remoteAuthUseSA` parameters, which select whether a Service Account file is used for authentication to the local or remote site. PNR and later supports Service Account authentication for importing or exporting configuration data.

Audit logging records replication and recovery operations and security-relevant events. PNR records operational information in log files that do not contain private keys or passwords. Authorization errors and certificate verification errors are written with timestamps and component information to security-related log files for audit trail purposes. Replication lifecycle events

generate audit log entries, for example the AutoprotectEnabledRpEvent entry that indicates Automatic Protection has been activated for a replication provider.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) incorporates multiple identification and access management mechanisms that support organization-wide IAM controls within the data services layer.

DSM implements role-based access control with two defined roles: the DSM Admin role, which can create, monitor, and manage all data services in the environment, and the DSM User role, which is restricted to managing and monitoring data services within the namespaces to which the user has been granted access. These roles are assigned at user creation time and govern what each user can see and do within the DSM interface. The Permissions view in the DSM dashboard provides administrators with a centralized location for creating, monitoring, and managing all configured users.

DSM supports two identity sources, which can be used independently or together. Local users are created directly within DSM, with credentials validated by matching email address and password. LDAPS users are sourced from a configured LDAP identity provider, allowing organizations to extend their existing directory service into DSM. When LDAPS is configured, administrators can import users from the directory provider and assign them DSM Admin or DSM User roles. DSM also supports group-based access control: Directory Service Groups from the LDAP provider can be assigned roles directly, so group membership in the external directory determines access level in DSM without requiring per-user assignments.

At the database level, DSM extends authentication controls beyond the platform management layer. MySQL database instances support LDAPS authentication using Active Directory. PostgreSQL and other database instances support host-based authentication (HBA) rule configuration, which determines which clients are permitted to authenticate to a given database instance. SQL Server instances support Windows Authentication through Active Directory integration, enabling Kerberos-based authentication so that clients such as SQL Server Management Studio running on domain-joined machines can authenticate via single sign-on. SQL Server also uses contained database users, where identity information resides within the database itself rather than at the server level. Administrators can configure SQL Server instances with either a SQL User or Windows Principal as the primary administrator identity, with Windows Principal available for Active Directory-integrated clusters. An internal `dsm_mgmt` management login restricts users from accessing or modifying system-level objects, keeping administrative operations within an isolated context.

Namespace isolation adds a further access boundary. DSM namespaces enforce role-based access control that allows multiple users to work jointly on data services within a namespace while remaining isolated from data services in other namespaces. This supports least-privilege access within multi-tenant deployments.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer contributes to Zero Trust Architecture by enforcing authentication and authorization at the application delivery layer before client requests reach protected workloads. Avi's SSO Policy, configured per virtual service, supports Authentication Rules and Authorization Rules that validate JSON Web Tokens, OAuth 2.0 access tokens, and OIDC claims on every incoming request. Clients that present invalid or absent credentials are denied access before any request is forwarded to the backend resource. This per-virtual-service enforcement model means each application can independently require successful authentication as a condition of access.

Auth Mapping Profiles extend this authentication model into the Avi Controller's administrative plane. These profiles map authenticated user identities, including identities sourced from LDAP, SAML, or other external directory services, to specific tenants and roles with varying permission levels. Auth Mapping rules can be configured to deny all privileges to specific users, blocking them from obtaining any role or tenant assignment on login. When remote authentication is configured, administrators can independently enable or disable local user login, supporting stricter authentication policy enforcement. A user without a matching rule in the Auth Mapping Profile receives no privileges on login. Auth Mapping Profiles should be configured to enforce tenant isolation except for designated super users who require cross-tenant access.

At the management plane, administrators can restrict the source IP address ranges permitted to reach the Avi Controller and enforce strong password requirements. User Account Lockout is implemented on the Controller as a mechanism that blocks

access after repeated failed authentication attempts. User accounts can be scoped to specific tenants and granted different roles within each tenant, limiting the blast radius of a compromised credential. HTTP security policies attached to virtual services are configurable to meet the security requirements applicable to each deployed application.

In VCF-integrated deployments, the Avi PKI Profile contains the list of Trusted Authorities allowed to sign client certificates and can be used to implement Zero Trust security between the server and the client. This certificate-based mechanism supports mutual authentication at the application delivery tier, complementing token-based authentication for workloads that rely on client certificate validation rather than OAuth or OIDC flows.

Full Zero Trust Architecture across a VCF environment requires capabilities beyond what Avi provides at the application delivery tier. Network-layer microsegmentation between workloads is provided by VMware vDefend, which is a separate product. OAuth, OIDC, and SAML federation require an external identity provider. The organizational policies that govern how authentication is enforced for all users and all devices must be defined and maintained by the organization; Avi provides the enforcement point for application traffic but does not itself constitute a complete ZTA implementation.

Control Tenet 7

The enterprise collects as much information as possible about the current state of assets, network infrastructure and communications and uses it to improve its security posture. An enterprise should collect data about asset security posture, network traffic and access requests, process that data, and use any insight gained to improve policy creation and enforcement. This data can also be used to provide context for access requests from subjects (see Section 3.3.1).

SCF Controls: AST-02.6, AST-02.8, AST-02.9, DCH-24.1, GOV-05, MON-01, MON-01.2, MON-01.4, MON-02, MON-02.1, MON-02.2, MON-02.3, NET-14.7, THR-01, THR-03

Aggregate Coverage: Meets

VCF (Meets)

VCF provides automated mechanisms to integrate audit record analysis with vulnerability scanning data, network performance monitoring, system monitoring, and other operational sources across the infrastructure stack. This integration is achieved through several interconnected components. VCF Operations is the centralized monitoring and analytics platform, and VCF Log Management aggregates log data from multiple VCF components into a unified collection point.

VCF Log Management can be configured to pull tasks, events, and alerts from VMware vCenter instances and receive syslog feeds from VMware ESX hosts through its Log Collections configuration. This brings audit records from across the infrastructure into a single platform where they can be analyzed alongside operational and performance data. VCF Log Management collects and aggregates log data from vCenter and ESX hosts, providing dashboards and analytics for centralized log analysis that spans the full infrastructure stack.

VCF Operations itself generates audit events across a broad set of categories, including Access, Access_control, Account_management, Configuration, Data_access, Network, Notification, Permissions, Session, System, Policy, and Firewall. Each audit event includes a detailed view containing information that supports analysis of events in the virtual infrastructure for suspicious user actions or system issues. The event auditing capability provides visibility into platform interaction changes across the VCF infrastructure and surfaces suspicious access events and policy violations. Audit events capture platform interactions such as user logins, logouts, capability checks, and configuration modifications.

The audit log in VCF Operations is integrated with the syslog subsystem, and the syslog collector can be configured to collect all audit logs. This integration allows audit records to flow through the same infrastructure as system and application logs, facilitating correlation. VCF Operations can also send user activity logs to an external syslog server for security auditing, enabling correlation with third-party SIEM or security analytics platforms. System audit reports can be downloaded in PDF or XLS format for offline analysis and compliance review.

VCF Operations provides several capabilities that support cross-source analysis and anomaly identification. Metric correlation runs on all metrics for a selected object to find metrics with similar or opposite behavioral change over the same time period, using both self-metrics and peer-object options. This allows administrators to correlate audit activity with performance deviations across the infrastructure. VCF Operations also supports dynamic thresholds for metrics, calculated based on historical and incoming data, which generate alerts when current values fall outside trended ranges. Dynamic threshold analysis uses a period of seven days of historical data before generating alerts. Alert definitions support metric event symptoms based on events from monitored systems where a selected metric violates a threshold, enabling automated responses when performance metrics indicate unusual activity.

VCF Operations collects OS and Application Monitoring Properties for operating systems, application services, remote checks, Linux processes, and Windows services, which can be used to create reports, views, and dashboards that combine audit data with system performance and health metrics. Self-monitoring metrics track internal health indicators such as CheckThresholdAndHealth outcome observations. Sensor metrics including temperature, fan speed, and fan health state are collected for host systems, broadening the scope of monitored data available for correlation with audit records.

At the host and network layer, ESX hosts can be configured to send syslog messages to a remote log server using the `esxcli system syslog config set` command, with configurable log levels to control the detail captured. The `Syslog.global.auditRecord.remote` parameter specifically enables forwarding of security audit records to the remote host defined by `Syslog.global.logHost`, providing a dedicated control for audit-record transmission that is separate from general syslog configuration. vCenter supports syslog forwarding to up to three remote servers using TCP, UDP, TLS, or RELP protocols, allowing audit records from across the VCF stack to be sent to a SIEM or log aggregation platform. Event streaming from vCenter to a remote syslog server can be enabled independently through the `vpxd.event.syslog.enabled` option, configured in the vCenter Management Interface. NSX audit logs are sent directly to the remote syslog server, and NSX logging and auditing capabilities can be integrated with logging and monitoring solutions to monitor for security events and anomalies. NSX Manager syslog supports TLS protocol on port 6514 for encrypted log transmission. NSX nodes can be configured to send syslog messages to multiple remote servers, each with independently specified port numbers and protocols.

VCF Operations for Networks provides its own audit log, which is integrated with syslog so that network monitoring data can be collected alongside infrastructure logs. VCF Operations for Networks can be configured to send problem alerts and platform or collector syslogs to remote syslog servers. Audit log data from VCF Operations for Networks can also be exported in CSV format for offline analysis.

The vCenter alarm infrastructure integrates with other server components such as events and performance counters, and supports metric-based alarm expressions that can trigger alerts when performance metrics indicate unusual activity. VCF PowerCLI supports creating metric-based alarm triggers with `New-AlarmTrigger` to define thresholds and conditions for CPU usage and other performance metrics. vCenter can also create alarms to monitor events on vSAN objects, including the cluster, ESX hosts, datastores, networks, and virtual machines.

Integration with external systems extends the correlation capabilities further. In integrated environments, VCF Automation insights and alerts for monitored objects can be accessed alongside VCF Operations data through the Alerts tab in the VCF Automation main menu, providing cross-product visibility. A ServiceNow Details dashboard provides status, relationships, health, alerts, and KPIs for monitored resources, connecting infrastructure monitoring data with IT service management workflows.

VMware vDefend (Contributes)

VMware vDefend contributes to data action mapping through its Security Intelligence and Security Services Platform (SSP) components, which provide network-level visibility into how data flows between workloads, applications, and infrastructure tiers. While creating and maintaining a formal map of where sensitive data is stored, transmitted, or processed is an organizational activity, vDefend provides the traffic analysis and asset inventory capabilities that inform such mapping efforts.

Security Intelligence collects and visualizes network traffic flows between compute entities, displaying source and destination details for each flow including VMs, IP addresses, groups, and applications. Asset collections in Security Intelligence include groups, infrastructure assets, environments, and applications and application tiers, providing a structured view of communication patterns across the environment. The Computes View displays the types of traffic flows that have occurred between compute entities during a selected time period. The Deep Dive action shows all compute entities belonging to a group and all groups that had traffic flows with those members during the selected time period, enabling teams to trace data movement paths across the environment. Security Intelligence maintains a Workload Classification table that stores and displays compute entity classifications, which can be modified through the administrative interface. Labels can be assigned to compute entity nodes through the contextual menu in the Computes View, and the Labels panel provides an Export as CSV function that downloads a file containing compute entities assigned to labels, including object ID, name, compute type, and IP address details. Policy recommendations generated from traffic flow analysis support segmentation strategy actions with allow or drop rules.

Security Services Platform organizes monitored assets into a hierarchy of regions, zones, environments, applications, and application tiers. The Platform Inventory view allows assets to be browsed by Regions & Zones with hierarchical grouping that expands to show assigned tags with their respective scopes. The SSP Platform Inventory also collects and displays VM tags

with their respective scopes for asset tracking and classification. Segmentation analysis maps inventory asset information from CSV files for publishing to NSX Manager, categorizing assets into infrastructure assets, regions and zones, environments, and applications. Security Intelligence combines this CSV-imported inventory data with infrastructure server data based on traffic flows discovered by Security Intelligence, producing a unified view available in the Summary tab. Security Intelligence discovers environments in the infrastructure after ingesting CSV file data and provides recommendations based on inter-environment traffic flows. The Segmentation Hierarchy and Infrastructure Services view displays the entire inventory assets hierarchy organized by region, zone, environment, application, and tier, with each scope listing the total number of assets included.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides monitoring capabilities specific to the disaster recovery domain and integrates with the broader VCF monitoring ecosystem through dedicated Protection and Recovery dashboards in VCF Operations. VCF Operations collects configuration, component health, and usage information from protection and recovery servers and site pairs, presenting this through an overview dashboard that displays all site pairs, configurations, health scores, and protection and recoverability status for sites and virtual machines. PNR provides default health alerts for protection groups, recovery plans, cloud file systems, recovery SDDCs, and protected sites through VCF Operations, and the dashboards surface alerts informing administrators about configurations and deployments that require attention. Separate dashboard views cover vSAN Snapshots and Replication monitoring, and an Inventory view provides health status, metrics, alerts, and network topology for all monitored objects.

Within its own domain, PNR provides event logging and configurable alarms for replication and recovery operations. Administrators can create alarms that trigger on specified event conditions, with support for email notifications, SNMP traps, or script execution in response. PNR monitors connections between sites by sending periodic ping requests, logs connection check events, and generates alarms when broken connections are detected. The alarm system generates warning-level alerts for expired snapshot schedules, replication errors such as missing VMs, and connectivity issues with protected and target sites. PNR also monitors resource consumption on the Protection and Recovery Server host and raises alarms when configurable resource thresholds are reached.

PNR includes a health monitoring service that checks each health finding every five minutes and records a timestamp at each check. Health findings are tracked with status history that can be reviewed over configurable time periods, defaulting to a 24-hour window. The Protection and Recovery Appliance supports syslog forwarding to a remote syslog server for log analysis and centralized monitoring, allowing appliance-level events to flow into existing log management infrastructure.

The Clean Room Orchestrator, part of PNR's Cyber Recovery capabilities, supports monitoring of clean room events, tasks, and alarms for recovery operations. Clean Room Orchestrator can forward events to VCF Operations, Microsoft Sentinel, or Splunk Cloud for centralized monitoring, supporting organizations that require DR event data to flow into enterprise SIEM and log management platforms as part of a broader monitoring strategy. The Clean Room Orchestrator integrates with endpoint detection and response tools, including CrowdStrike and Carbon Black sensor appliances, for threat detection within isolated recovery environments.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to enterprise-wide monitoring controls through a layered set of observability capabilities covering database health, infrastructure compliance, and event-driven alerting.

DSM provides a built-in monitoring framework that tracks database instance health across multiple dimensions. From the Monitoring tab in the DSM UI or the vSphere Client, administrators and authorized users can view real-time and historical metrics for database VMs, including CPU Health, Data Disk Health, System Disk Health, Max Connections, Active Connections, Write Throughput, Read Throughput, Thread Resource Utilization, Slow Queries per Second, InnoDB Buffer Usage, and InnoDB Reads and Writes. The Monitoring page defaults to the last three hours of aggregated metric data, with the time range adjustable through the Time Range Last dropdown. This visibility supports detection of resource contention, performance degradation, and connectivity anomalies at the database layer.

DSM's alert framework provides configurable thresholds for warning and critical conditions on key health indicators. Administrators and users can set separate warning and critical thresholds for CPU Health, Data Disk Health, System Disk Health, and Max Connections parameters. When thresholds are exceeded, DSM generates typed alerts such as Database Engine Health, Custom Config Health, and Backup Storage Health alerts. DSM monitors database replication status and raises an alert when a secondary database is not replicating data from the primary. DSM also raises an alert when metrics are no longer being received from a cluster, supporting detection of monitoring gaps. Alerts can be activated or deactivated per data service through the "Enable Alerts for DB Alert" setting, providing granular control over which databases are subject to active alerting. For each alert, DSM provides mitigation suggestions to help administrators resolve issues without disrupting database services.

In addition to database-level alerts, DSM generates global infrastructure alerts that surface vCenter integration and infrastructure policy issues. These include `INFRASTRUCTURE_POLICY_VC_ALARMS`, raised when vCenter resource alarms are active; `INFRASTRUCTURE_POLICY_CLUSTER_COMPLIANT` and `INVALID_SUPERVISOR_INFRASTRUCTURE_POLICY_STATUS`, which reflect cluster compliance state; `VCENTER_CONNECTIVITY`, raised when vCenter connectivity fails and triggering troubleshooting steps that include verifying connectivity and checking authentication logs; and `LicensingNotUpdated` and `vCenterBinding` API status alerts that surface license and API integration conditions. A Global Alerts page in the DSM UI provides a centralized view of these alerts during and after installation and ongoing operation.

In 9.1, DSM integrates with VCF Operations to extend observability beyond the DSM UI. When configured, VCF Operations automatically discovers and monitors PostgreSQL and MySQL clusters in the Ready state and displays a Data Services View dashboard showing active alerts and inventory items. VCF Operations presents performance data across three levels: cluster-level for overall health, node-level for infrastructure resource use, and database-level for KPIs including Active Connections, Commits, Rollbacks, and Deadlocks. This integration requires configuring the connection between DSM and VCF Operations before use.

DSM also adds SQL Server as a supported database type, with dedicated monitoring through an integrated InfluxDB instance and Telegraf agents deployed across the provider appliance and SQL Server workload clusters. The monitoring framework supports metrics-based and status-condition-based alerts for SQL Server, covering database engine degradation, non-operational status, and automated or transaction log backup failure conditions.

DSM supports event notification to external systems through a webhook integration. Webhooks transmit alert notifications containing the triggered date, triggered time, triggered user email, task status, previous status, and task type. This allows DSM alerts to feed into centralized monitoring or incident management platforms maintained by the organization. DSM generates plug-in registration logs that administrators can review for vCenter connectivity errors, and DSM's troubleshooting guidance directs administrators to review active vCenter infrastructure alarms and resolve underlying issues identified through the alert system.

Enterprise-wide monitoring requires organizational decisions about monitoring architecture, log aggregation platforms, alerting policies, and operational response procedures that lie outside DSM's scope. DSM provides the data and integration points; the organization must determine how those signals are collected, correlated, and acted upon across the broader environment.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides multiple mechanisms for forwarding security-relevant event logs to external centralized collection systems, including SIEM platforms, syslog aggregators, and log analytics tools.

The Avi Controller exports logs through syslog forwarding, configured via the `configure systemconfiguration` CLI command or through the Controller Settings interface. The `syslog_servers` setting specifies one or more external syslog destinations. Syslog configuration is synchronized from the Controller to Service Engines, so data-plane events from Service Engines are also forwarded to the same targets.

For audit-focused event streaming, Avi provides Syslog-Audit-Persistence, a built-in alert action template that streams audit and security events to external syslog servers. Events forwarded in this mode are encoded in

SYSLOG_RFC5425_ENHANCED format, which includes event type, object name, tenant identifier, timestamp, and the identity of the user who performed the action. Syslog transport supports both TCP (with TLS) and UDP with a configurable destination port (default 514 per RFC 5426). This covers administrative configuration changes, object-level audit events, and security alert notifications.

The Avi Controller and Service Engines log audit records for trusted channel initiation, termination, and failures to Events, Syslog, and Splunk, providing complete traceability of encrypted communication lifecycle events. The Avi DataScript engine supports logging of security events such as blocklisted IP access attempts using the `log()` function, making application-layer policy enforcement decisions available to the central log collector.

Beyond the audit stream, Avi supports streaming client application logs to external syslog or logging servers for centralized monitoring and compliance audit trails. WAF Application Rule events are captured when a WAF rule fires, recording the type of attack detected and matched variable content, and these events can be forwarded to the same external collection targets. The Avi Controller also logs denial of service attack events with structured details including event ID, attack count, threshold values, and alert level.

Avi supports integration with VCF Log Management. A VCF Log Management Log Forwarder can be configured as a syslog destination in the Avi Controller to receive events. The VCF Log Management agent, installed on an external syslog server, can parse JSON log data and forward it to the Log Forwarder. The recommended integration pattern routes logs through an intermediate proxy for JSON parsing, enabling key extraction and facilitating querying of client logs. Note that virtual service client logs should not be sent directly from the Service Engine to a Log Forwarder; the recommended path routes through an intermediate syslog server.

The Avi Analytics Profile supports streaming of client logs to multiple external servers simultaneously, including IPv6 destinations. For assured retention of all logs, Avi documentation recommends streaming logs directly to an external server such as Splunk rather than relying on local storage. In air-gap environments, the remote syslog server must be located within the environment perimeter.

The Avi Event Log system records all system activities, configuration changes, and operational events, including who made each change and when. Global event logs are accessible via the Operations > All Events page in the Avi UI, covering all objects including deleted objects and sub-objects such as profiles and certificates. A REST API endpoint allows retrieval of event logs for a specific time period to support automated log collection workflows. Events can be filtered by type using parameters such as `event_id=CONFIG_CREATE` or `event_id=CONFIG_UPDATE` to identify configuration activity.

Note that system component debug logs are not sent to remote syslog servers and are available only through the Tech Support generation mechanism. Similarly, virtual service logs are not pushed automatically via syslog notification; they must be pulled from an external logging system through the API or configured separately to be pushed from the Controller.

To configure centralized log forwarding, navigate to Controller Settings and enter the target syslog server address in the Syslog configuration. For audit event streaming specifically, configure the Syslog-Audit-Persistence alert action template. For VCF Log Management integration, configure a Log Forwarder as a syslog destination in the Controller and optionally deploy the VCF Log Management agent on an intermediate syslog server for JSON parsing.

